



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services



دبلوم امن المعلومات

الفصل 2: مكوّنات التصميم الأمني



دبلوم امن المعلومات

● اسم المقرر:

مبادئ التصميم في الأمن السبراني

● رمز المقرر:

ISE125

● الموضوع:

الفصل 2: مكونات التصميم الأمني



يقارن نماذج DAC و MAC و RBAC و ABAC ويختار الأنسب
لسيناريو مؤسسي.



يميز بين المصادقة والتفويض والمحاسبة في تصميم التحكم في
الوصول.

يطبق الدفاع بالعمق بتعيين ضابط لكل طبقة.



يشرح دور التشفير وتكامل البيانات بوصفهما مكوّنين
تصميميين.



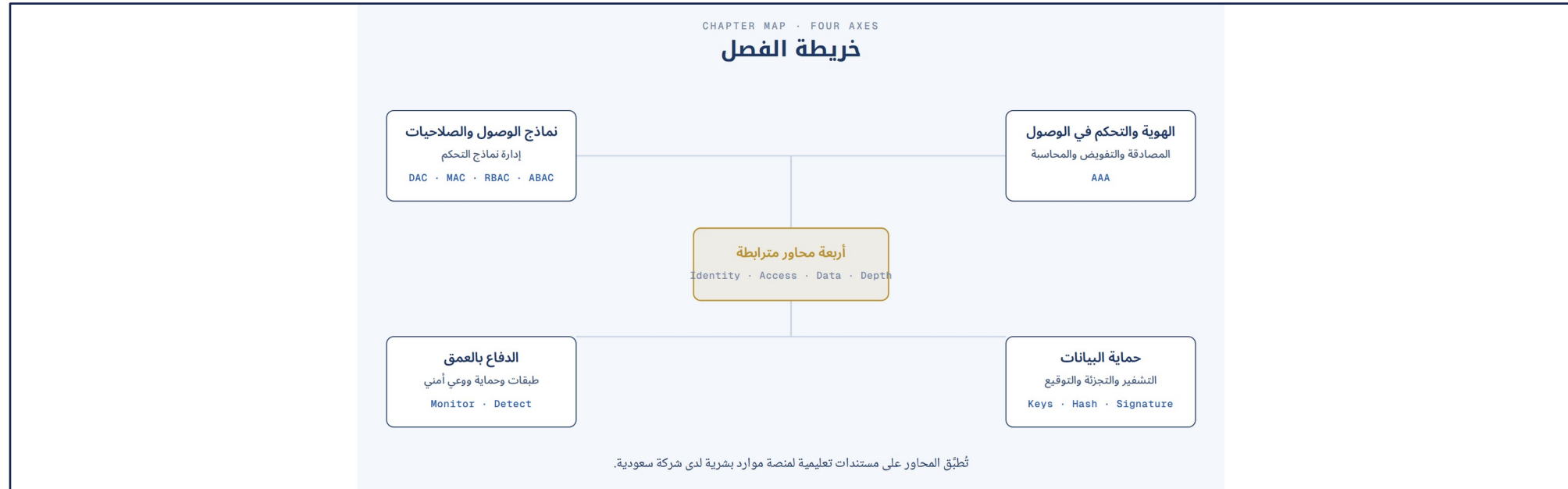
يصمم مصفوفة وصول مبسطة لنظام خدمات مع تبرير فصل المهام.





خريطة الفصل

ينتظم الفصل في أربعة محاور مترابطة:





الزمن التقديري	مكوّن التعلم
175 دقيقة	دراسة المحتوى الرقمي والقراءات
85 دقيقة	أنشطة تطبيقية وحالات تحليلية
60 دقيقة	اختبار قصير وواجب تطبيقي
40 دقيقة	المرحلة الثانية من المشروع التراكمي
360 دقيقة	إجمالي الفصل

ينفذ المتعلم المرحلة الثانية من المشروع بإعداد مصفوفة التحكم في الوصول وطبقات الدفاع بالعمق للنظام الذي اختاره.



مكوّنات التصميم الأمني هي قرارات مترابطة تحدد كيف تثبت الهوية، وكيف تمنح الصلاحيات، وكيف تحفظ الأدلة، وكيف تحمي البيانات عبر طبقات متعددة.

لا يكفي اختيار أداة منفردة، لأن فاعلية التصميم تعتمد على اتساق الهوية والوصول والتشفير والمراقبة. في منصة موارد بشرية، تتكامل هذه القرارات لحماية السجلات وأوامر الصرف وسجل التدقيق.



التحكم في الوصول (Access Control)



- ◀ التحكم في الوصول هو مجموعة سياسات وآليات تقرر من يصل إلى مورد أو عملية، وما الفعل المسموح، وتحت أي شروط.
- ◀ وظيفته منع الوصول غير المصرح به وتقييد الأفعال ودعم تتبع القرار الأمني.
- ◀ **الوظيفة:** فرض قرار الوصول المناسب.
- ◀ **المسؤوليات:** تعريف الموارد الحساسة، تحديد الهويات، ضبط الصلاحيات، فرض القرار، مراجعة الاستثناءات.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، سياسات الوصول المؤسسية.
- ◀ **الأجهزة:** خدمات الهوية، محركات السياسة، قواعد بيانات الصلاحيات، سجلات التدقيق، بوابات الوصول.
- ◀ **وحدة البيانات:** قرار سماح أو رفض أو طلب تحقق إضافي.
- ◀ **مثال:** يمنح موظف المالية إنشاء أمر صرف، ولا يمنحه اعتماد الأمر نفسه.



التحكم في الوصول (Access Control) (الشكل)



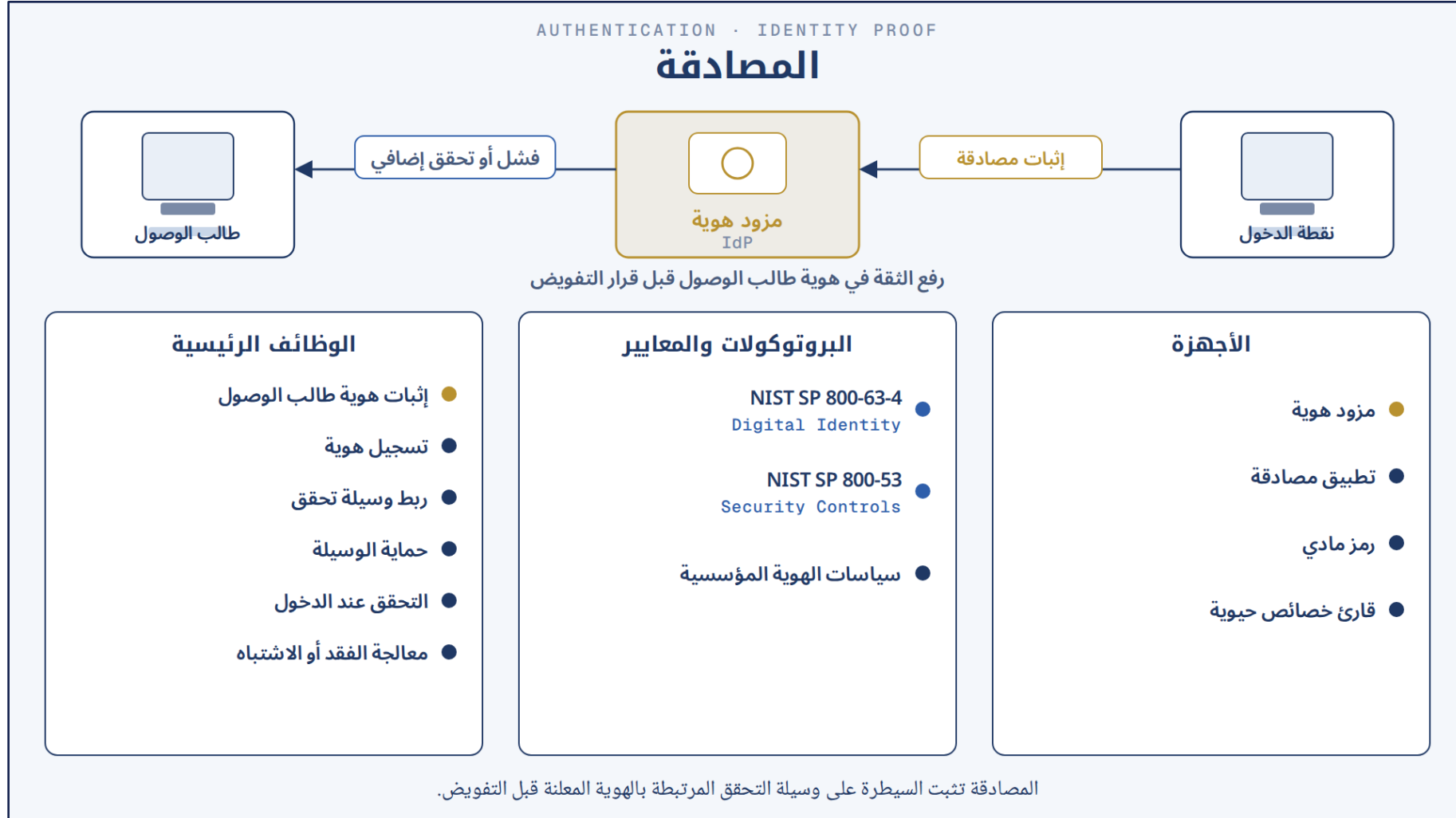


المصادقة (Authentication)

- المصادقة هي التحقق من أن طالب الوصول يثبت سيطرته على وسيلة تحقق مرتبطة بالهوية المعلنة.
- وظيفتها رفع الثقة في هوية طالب الوصول قبل اتخاذ قرار التفويض.
- الوظيفة:** إثبات هوية طالب الوصول.
- المسؤوليات:** تسجيل هوية، ربط وسيلة تحقق، حماية الوسيلة، التحقق عند الدخول، معالجة الفقد أو الاشتباه.
- البروتوكولات والمعايير:** NIST SP 800-53، NIST SP 800-63-4، سياسات الهوية المؤسسية.
- الأجهزة:** مزود هوية، تطبيق مصادقة، رمز مادي، قارئ خصائص حيوية.
- وحدة البيانات:** إثبات مصادقة أو فشل مصادقة أو طلب تحقق إضافي.
- مثال:** يسجل الحساب fin-ops-01 دخوله بنجاح بعد مصادقة متعددة العوامل.



(الشكل) (Authentication) المصادقة





(Authorization) التفويض

- ◀ التفويض هو قرار يحدد العمليات والموارد المتاحة لهوية تم التحقق منها وفق سياسة معلنة.
- ◀ وظيفته تطبيق أقل الامتيازات وتقييد الوصول بحسب الدور أو السمات أو التصنيف أو السياق.
- ◀ **الوظيفة:** منح صلاحية مقيدة بالسياسة.
- ◀ **المسؤوليات:** تحديد السياسة، تعيين الصلاحيات، تقييم الطلب، تسجيل القرار، مراجعة الصلاحيات.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، سياسة الصلاحيات الداخلية.
- ◀ **الأجهزة:** محرك سياسات، مصفوفة صلاحيات، خدمة أدوار، مخزن سمات، واجهة إدارة الصلاحيات.
- ◀ **وحدة البيانات:** قرار سماح أو رفض أو صلاحية محددة المدة.
- ◀ **مثال:** يرفض النظام طلب fin-ops-01 لاعتماد أمر الصرف PAY-260414-117 بسبب تعارض فصل المهام.



(الشكل) (Authorization) التفويض

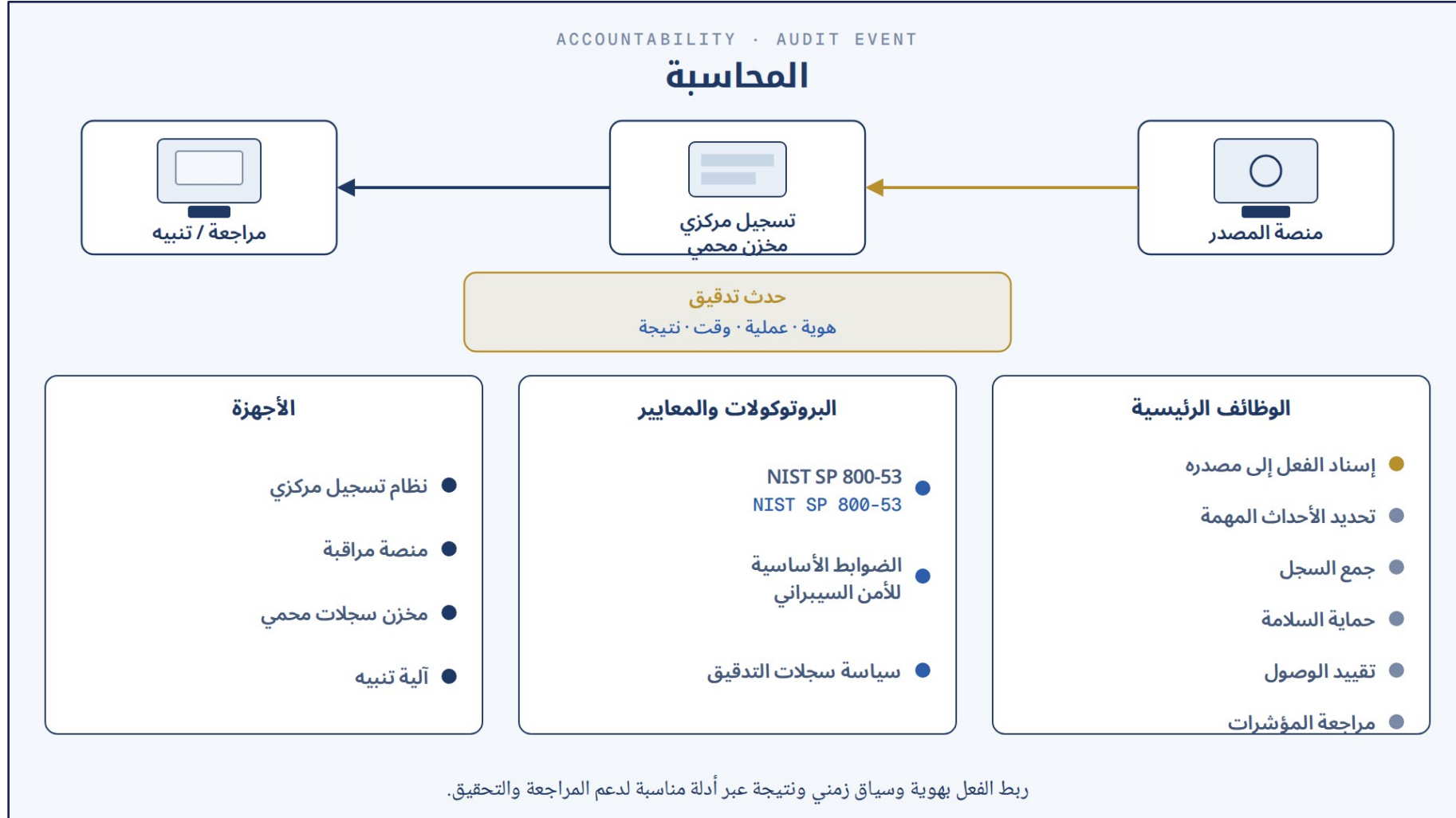




- المحاسبة هي قابلية ربط فعل أو حدث بهوية وسياق زمني ونتيجة من خلال أدلة مناسبة.
- وظيفتها دعم المراجعة والتحقيق وكشف السلوك غير المعتاد وتحسين الضوابط.
- الوظيفة:** إسناد الفعل إلى مصدره وسياقه.
- المسؤوليات:** تحديد الأحداث المهمة، جمع السجل، حماية السلامة، تقييد الوصول، مراجعة المؤشرات.
- البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، سياسة سجلات التدقيق.
- الأجهزة:** نظام تسجيل مركزي، منصة مراقبة، مخزن سجلات محمي، آلية تنبيه.
- وحدة البيانات:** حدث تدقيق يتضمن هوية وعملية ووقتاً ونتيجة.
- مثال:** يربط سجل المنصة اعتماد أمر الصرف بالحساب fin-approve-01 والوقت 09:30:11.



(الشكل) (Accountability) المحاسبة

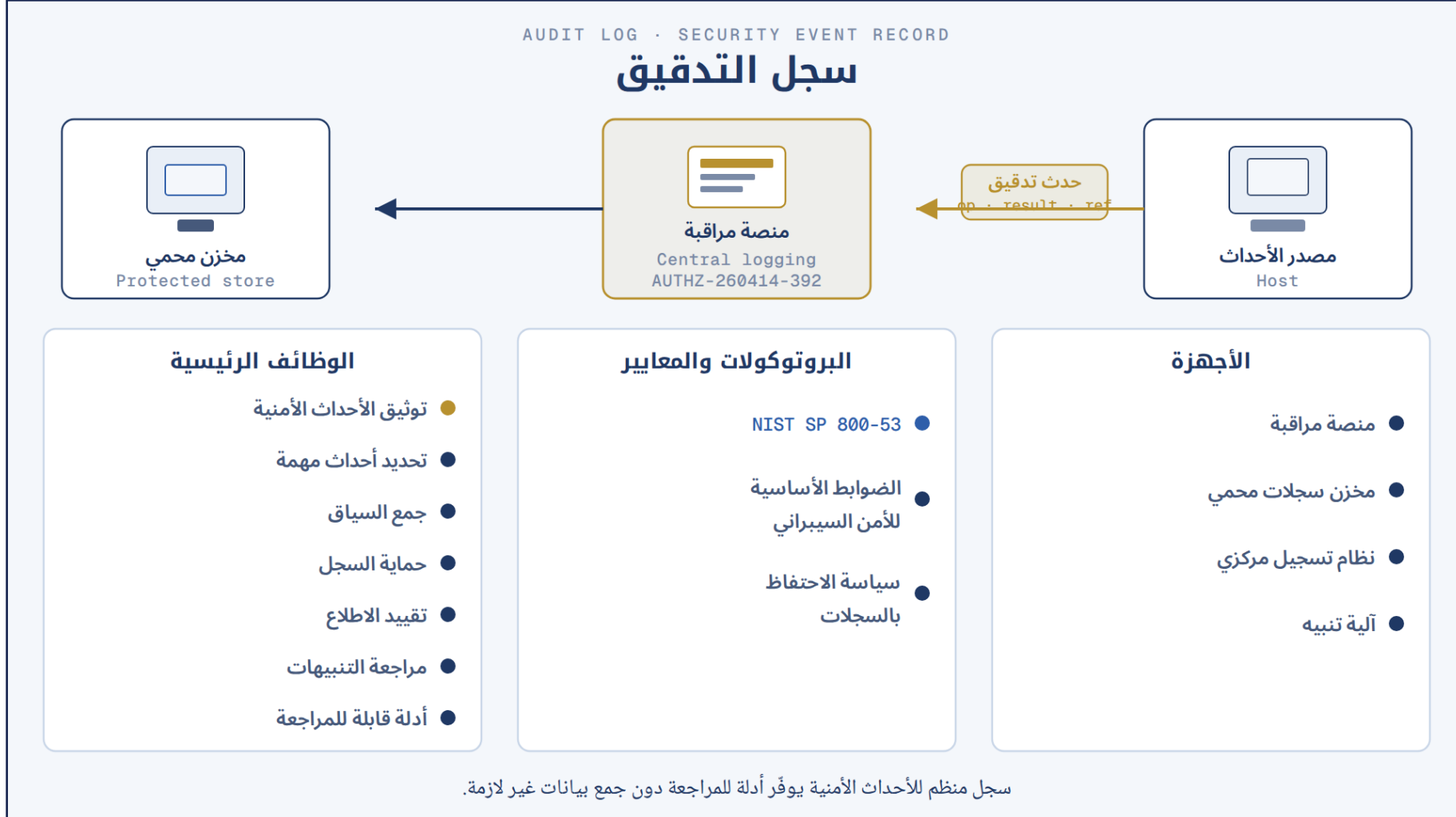




- ◀ سجل التدقيق هو سجل منظم للأحداث الأمنية، مثل محاولات الدخول وتغييرات الصلاحيات وقرارات الوصول.
- ◀ وظيفته توفير أدلة قابلة للمراجعة دون جمع بيانات غير لازمة.
- ◀ **الوظيفة:** توثيق الأحداث ذات الصلة بالأمن.
- ◀ **المسؤوليات:** تحديد أحداث مهمة، جمع السياق، حماية السجل، تقييد الاطلاع، مراجعة التنبيهات.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، سياسة الاحتفاظ بالسجلات.
- ◀ **الأجهزة:** منصة مراقبة، مخزن سجلات محمي، نظام تسجيل مركزي، آلية تنبيه.
- ◀ **وحدة البيانات:** حدث تدقيق يتضمن العملية والنتيجة والمرجع.
- ◀ **مثال:** يسجل المرجع AUTHZ-260414-392 رفض طلب اعتماد بسبب تعارض فصل المهام.



سجل التدقيق (Audit Log) (الشكل)



شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

سجل التدقيق الأمني لمنصة الموارد البشرية

الأحداث المرتبطة بأمر صرف داخلي خلال 14-04-2026

المرجع	النتيجة	العملية	عنوان الشبكة	الحساب والدور	الطابع الزمني
AUTH-260414-081	نجاح	تسجيل دخول مع مصادقة متعددة العوامل	10.24.18.31	ops-01-fin موظف المالية	2026-04-14 09:12:18
PAY-260414-117	نجاح	إنشاء أمر صرف بقيمة 7350 رس	10.24.18.31	ops-01-fin موظف المالية	2026-04-14 09:18:44
AUTHZ-260414-392	مرفوض: تعارض فصل المهام	طلب اعتماد أمر الصرف PAY-260414-117	10.24.18.31	ops-01-fin موظف المالية	2026-04-14 09:20:06
AUTH-260414-084	نجاح	تسجيل دخول مع مصادقة متعددة العوامل	10.24.18.46	approve-01-fin المعتمد المالي	2026-04-14 09:27:53
PAY-260414-117	نجاح	اعتماد أمر الصرف PAY-260414-117	10.24.18.46	approve-01-fin المعتمد المالي	2026-04-14 09:30:11
AUD-260414-029	نجاح	قراءة سجل أمر الصرف وسجل الرفض	10.24.18.58	review-01-audit مراجع التدقيق الداخلي	2026-04-14 10:04:39

يعرض السجل طابعاً زمنياً وحساباً وظيفياً وعنوان شبكة وعملية ونتيجة ومرجعاً قابلاً للتتبع. الحسابات وظيفية ولا تمثل أسماء أشخاص.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- أقرأ السجل زمنياً.
- يبدأ الحساب fin-ops-01 بمصادقة ناجحة عند 09:12:18، ثم ينشئ أمر صرف بقيمة 7350 ر.س. عند طلب الاعتماد، يسجل النظام رفضاً بسبب تعارض فصل المهام.
- بعد ذلك يعتمد الحساب fin-approve-01 الأمر نفسه.
- يبين السجل الفرق بين إثبات الهوية وقرار الصلاحية وتوثيق الحدث.



عوامل المصادقة (Authentication Factors)

- ◀ عوامل المصادقة وسائل تحقق ترتبط بسر أو حيازة أو خاصية، وتستخدم لإثبات سيطرة طالب الوصول على وسيلة مرتبطة بهويته.
- ◀ **الوظيفة:** رفع الثقة في هوية طالب الوصول قبل التفويض.
- ◀ **المسؤوليات:** اختيار العامل المناسب، ربطه بالهوية، حماية وسيلة التحقق، معالجة الفقد أو الاشتباه.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-63-4، سياسات الهوية المؤسسية.
- ◀ **الأجهزة:** مزود هوية، تطبيق مصادقة، رمز مادي، قارئ خصائص حيوية.
- ◀ **وحدة البيانات:** إثبات مصادقة أو فشل مصادقة أو طلب تحقق إضافي.
- ◀ **مثال:** يطلب النظام عاملاً إضافياً قبل إجراء إداري عالي الأثر، ثم يقيم التفويض بصورة مستقلة.



(الشكل) (Authentication Factors) عوامل المصادقة





خصص 10 دقائق لقراءة حالات دخول عادي وإجراء إداري عالي الأثر وطلب استعادة حساب.

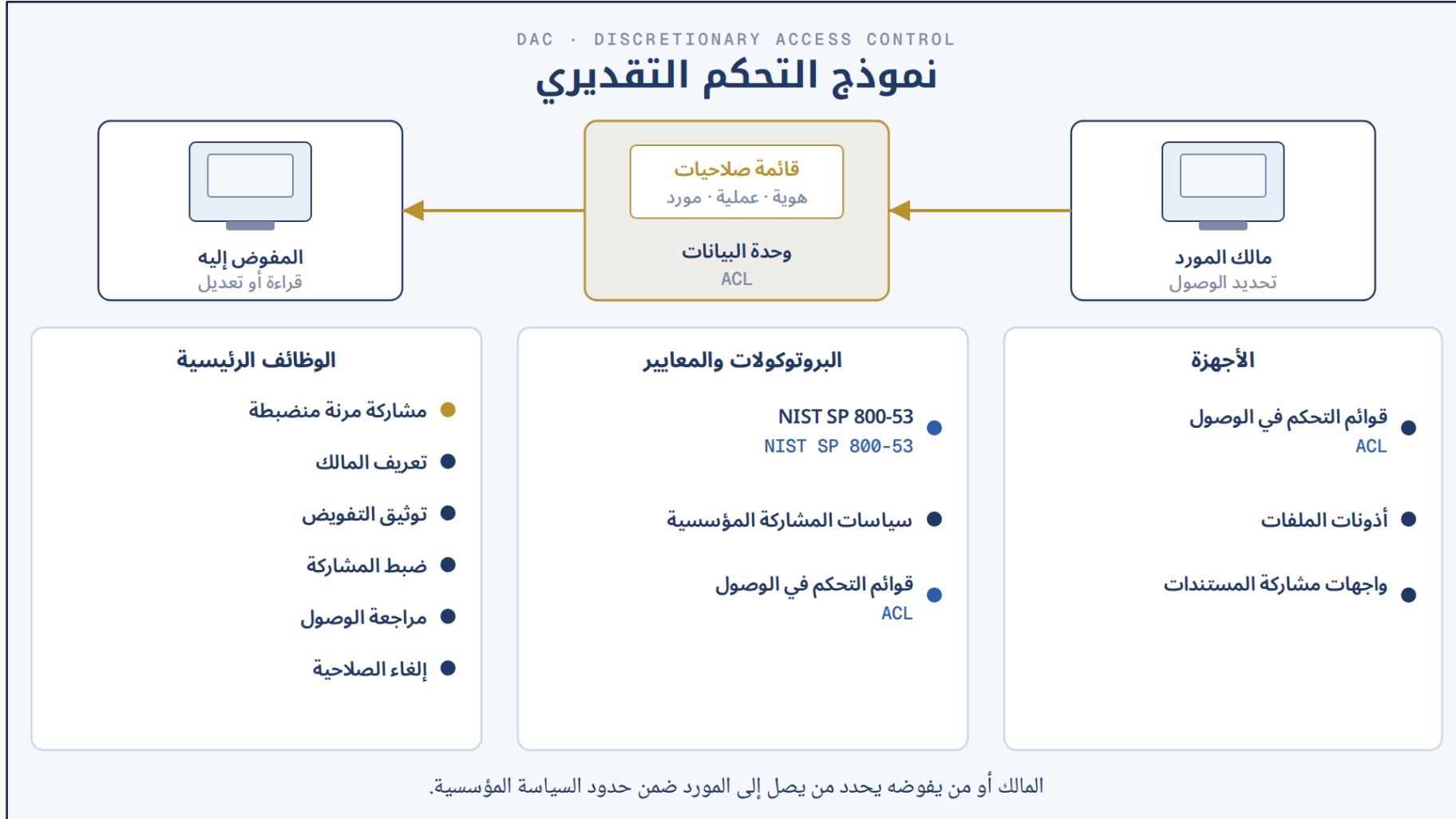
لكل حالة حدد وسيلة تحقق ملائمة من السر أو الحيازة أو الخصوصية، ثم اكتب سبباً يربط الاختيار بحساسية المورد ومخاطر الاستيلاء على الحساب. لا تمنح أي وسيلة تحقق حق تنفيذ العملية، لأن قرار التفويض يبقى مستقلاً عنها.



- ◀ التحكم التقديري هو نموذج يتيح لمالك المورد أو من يفوضه تحديد من يصل إلى المورد.
- ◀ وظيفته دعم مرونة مشاركة الموارد ضمن حدود السياسة المؤسسية.
- ◀ **الوظيفة:** تمكين المشاركة المرنة المنضبطة.
- ◀ **المسؤوليات:** تعريف المالك، توثيق التفويض، ضبط المشاركة، مراجعة الوصول، إلغاء الصلاحية.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، سياسات المشاركة المؤسسية، قوائم التحكم في الوصول.
- ◀ **الأجهزة:** قوائم التحكم في الوصول، أذونات الملفات، واجهات مشاركة المستندات.
- ◀ **وحدة البيانات:** قائمة صلاحيات تربط هوية بعملية على مورد.
- ◀ **مثال:** يحدد مالك مساحة عمل من يقرأ مستنداً داخلياً أو يعدله، مع مراجعة المشاركة عند انتهاء المهمة.



نموذج التحكم التقديري (DAC) (الشكل)

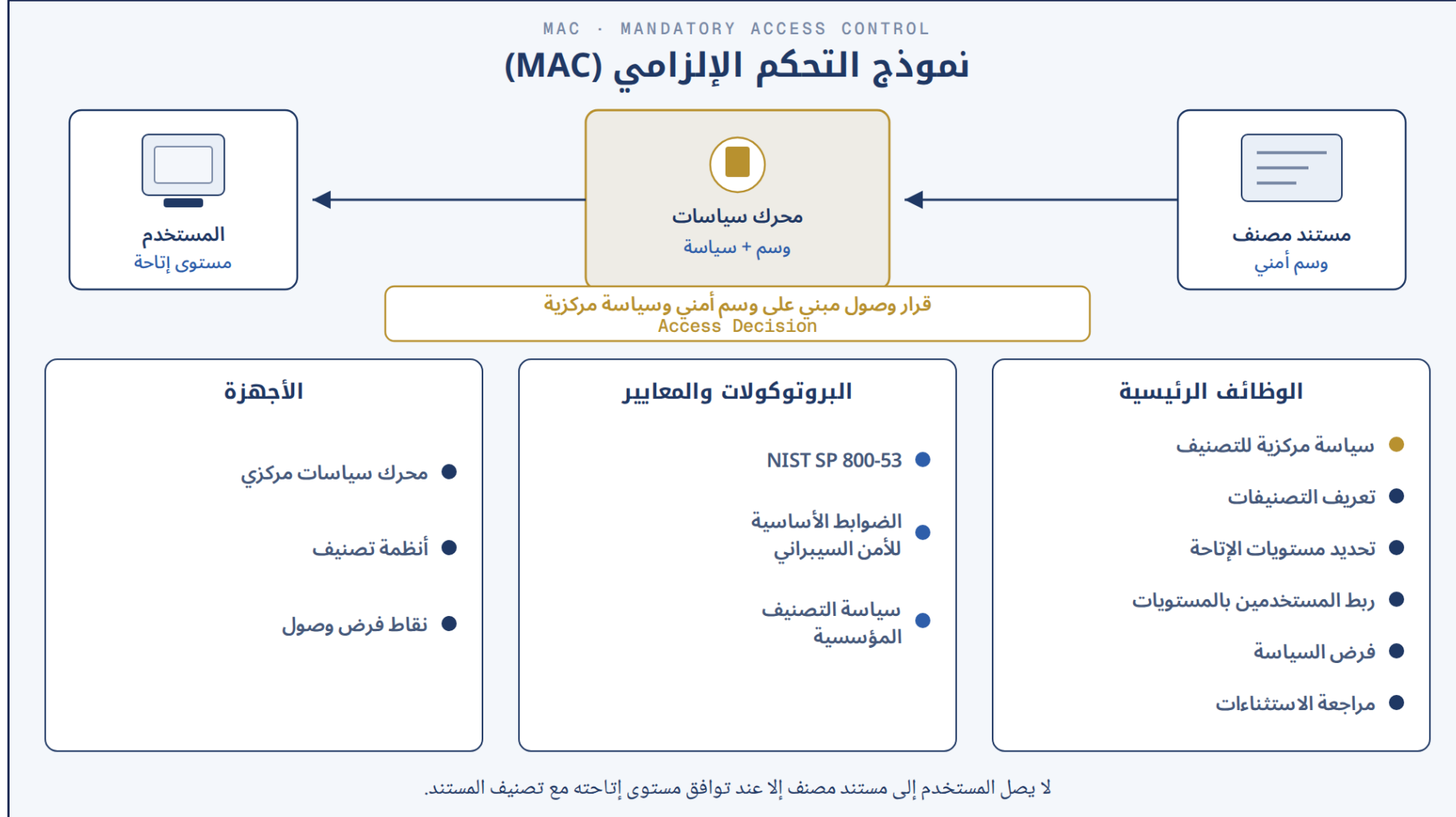




- ◀ التحكم الإلزامي هو نموذج تحكمه سياسة مركزية وتصنيفات أو مستويات أمنية، ولا يعتمد على تقدير مالك المورد وحده.
- ◀ وظيفته فرض قواعد موحدة على تدفق المعلومات والوصول إلى البيانات المصنفة.
- ◀ **الوظيفة:** تطبيق سياسة مركزية للتصنيف.
- ◀ **المسؤوليات:** تعريف التصنيفات، تحديد مستويات الإتاحة، ربط المستخدمين بالمستويات، فرض السياسة، مراجعة الاستثناءات.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، سياسة التصنيف المؤسسية.
- ◀ **الأجهزة:** محرك سياسات مركزي، أنظمة تصنيف، نقاط فرض وصول.
- ◀ **وحدة البيانات:** قرار وصول مبني على وسم أمني وسياسة مركزية.
- ◀ **مثال:** لا يصل المستخدم إلى مستند مصنف إلا عند توافق مستوى إتاحتته مع تصنيف المستند.



نموذج التحكم الإلزامي (MAC) (الشكل)





نموذج التحكم القائم على الدور (RBAC)



- ◀ التحكم القائم على الدور يمنح الأذونات للأدوار ثم يربط المستخدمين بهذه الأدوار.
- ◀ وظيفته تبسيط إدارة الصلاحيات وربطها بالمسؤوليات الوظيفية بدلاً من إدارتها لكل مستخدم منفرداً.
- ◀ **الوظيفة:** تنظيم الصلاحيات وفق الأدوار.
- ◀ **المسؤوليات:** تحليل المهام، تعريف الأدوار، إسناد الأذونات، إسناد المستخدمين، مراجعة تعارض المهام.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، مبدأ فصل المهام.
- ◀ **الأجهزة:** دليل هوية، نظام إدارة أدوار، مصفوفة صلاحيات، واجهة مراجعة وصول.
- ◀ **وحدة البيانات:** علاقة مستخدم-دور وعلاقة دور-صلاحية.
- ◀ **مثال:** يملك موظف المالية إنشاء أمر الصرف، بينما يملك المعتمد المالي اعتماد الأمر أو رفضه.



نموذج التحكم القائم على الدور (RBAC) (الشكل)



مصفوفة صلاحيات منصة الموارد البشرية

شركة الحلول التقنية والخدمات الرقمية						
تطوير وإدارة المنصات الرقمية والخدمات السحابية						
جازان، المملكة العربية السعودية						
الرقم الصريحي: 3000000000000003 - السجل التجاري: 1010000000						
هاتف: 0500000000						
مصفوفة التحكم في الوصول لمنصة الموارد البشرية						
إصدار تشغيلي بتاريخ 12-04-2026 لمنصة الحضور والعمليات المالية المصفوفة						
الدور	سجلات الموظفين	بيانات الحضور	أوامر الصرف	اعتماد الصرف	حسابات المستخدمين	سجل التدقيق
موظف الموارد البشرية	إنشاء وتعديل بيانات العمل	قراءة وتعديل سجلات الحضور	لا صلاحية	لا صلاحية	لا صلاحية	لا صلاحية
موظف المالية	قراءة الاسم الوظيفي فقط	لا صلاحية	إنشاء وإرسال أمر الصرف	لا صلاحية	لا صلاحية	لا صلاحية
المعتمد المالي	قراءة الاسم الوظيفي فقط	لا صلاحية	قراءة الأوامر المرسله	اعتماد أو رفض أمر الصرف	لا صلاحية	قراءة عمليات الاعتماد
مسؤول إدارة الهوية	لا صلاحية	لا صلاحية	لا صلاحية	لا صلاحية	إنشاء الحساب وإعادة تعيين كلمة المرور	قراءة سجلات المصادقة فقط
مراجع التدقيق الداخلي	قراءة دون تعديل	قراءة دون تعديل	قراءة دون تعديل	قراءة دون تعديل	لا صلاحية	قراءة جميع السجلات دون تعديل
قيد إلزامي: لا يمنح الدوران «موظف المالية» و«المعتمد المالي» للحساب نفسه، تخضع الصلاحيات لمبدأ أقل الامتيازات والحاجة إلى المعرفة. مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية						

- تقرأ المصفوفة الدور أولاً ثم المورد ثم العملية المسموح بها.
- يملك موظف المالية إنشاء وإرسال أمر الصرف، لكنه لا يملك اعتماده.
- يملك المعتمد المالي قراءة الأوامر المرسله واعتمادها أو رفضها.
- يحقق هذا التقسيم أقل الامتيازات وفصل المهام، ويمنع حساباً واحداً من إتمام سلسلة صرف عالية الأثر دون رقابة مستقلة.

مثال محلول على النموذج، مصفوفة RBAC وفصل المهام

شركة الحلول التقنية والخدمات الرقمية
تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

المستند: مصفوفة التحكم في الوصول لمنصة الموارد البشرية

مصفوفة التحكم في الوصول لمنصة الموارد البشرية
إصدار تشغيلي بتاريخ 12-04-2026 لمنصة الحضور والعمليات المالية المصغرة

الدور	سجلات الموظفين	بيانات الحضور	أوامر الصرف	اعتماد الصرف	حسابات المستخدمين	سجل التدقيق

قيد إلزامي: لا يمنح الدوران «موظف المالية» و«المعتمد المالي» للحساب نفسه، تخضع الصلاحيات لمبدأ أقل الامتيازات والحاجة إلى المعرفة.
مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- المعطيات: تتطلب منصة الموارد البشرية توزيع صلاحيات سجلات الموظفين والحضور وأوامر الصرف والحسابات وسجل التدقيق بين خمسة أدوار.
- يجب أن يستطيع موظف المالية إنشاء أمر صرف، بينما يجب أن يكون الاعتماد من دور مستقل.
- المطلوب بناء مصفوفة تمنع جمع الإنشاء والاعتماد في الحساب الواحد وتتيح المراجعة دون تعديل.

الخطوة 1 من 3: إدخال صلاحيات الموارد البشرية والمالية

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

المستند: مصفوفة التحكم في الوصول لمنصة الموارد البشرية

مصفوفة التحكم في الوصول لمنصة الموارد البشرية

إصدار تشغيلي بتاريخ 12-04-2026 لمنصة الحضور والعمليات المالية المصفوفة

الدور	سجلات الموظفين	بيانات الحضور	أوامر الصرف	اعتماد الصرف	حسابات المستخدمين	سجل التدقيق
موظف الموارد البشرية	إنشاء وتعديل بيانات العمل	قراءة وتعديل سجلات الحضور	لا صلاحية	لا صلاحية	لا صلاحية	لا صلاحية
موظف المالية	قراءة الاسم الوظيفي فقط	لا صلاحية	إنشاء وإرسال أمر الصرف	لا صلاحية	لا صلاحية	لا صلاحية

فقد إزامي: لا يمنح الدوران «موظف المالية» و«المعتمد المالي» للحساب نفسه، تخضع الصلاحيات لمبدأ أقل الامتيازات والحاجة إلى المعرفة.

مستند تعليمي إزامي: الأسماء والأرقام غير حقيقية

- يدون في الصف الأول دور موظف الموارد البشرية، مع إنشاء وتعديل بيانات العمل وقراءة وتعديل سجلات الحضور.
- يدون في الصف الثاني دور موظف المالية، مع قراءة الاسم الوظيفي فقط وعدم منحه صلاحية سجلات الحضور.
- يطبق ذلك الحاجة إلى المعرفة، لأن كل دور يحصل على المعلومات اللازمة لمهمته دون توسيع غير مبرر للصلاحيات.

الخطوة 2 من 3: فصل الاعتماد عن إدارة الهوية

المستند: مصفوفة التحكم في الوصول لمنصة الموارد البشرية

شركة الحلول التقنية والخدمات الرقمية
تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

مصفوفة التحكم في الوصول لمنصة الموارد البشرية

إصدار تشغيلي بتاريخ 12-04-2026 لمنصة الحضور والعمليات المالية المصغرة

الدور	سجلات الموظفين	بيانات الحضور	أوامر الصرف	اعتماد الصرف	حسابات المستخدمين	سجل التدقيق
موظف الموارد البشرية	إنشاء وتعديل بيانات العمل	قراءة وتعديل سجلات الحضور	لا صلاحية	لا صلاحية	لا صلاحية	لا صلاحية
موظف المالية	قراءة الاسم الوظيفي فقط	لا صلاحية	إنشاء وإرسال أمر الصرف	لا صلاحية	لا صلاحية	لا صلاحية
المعتمد المالي	قراءة الاسم الوظيفي فقط	لا صلاحية	قراءة الأوامر المرسله	اعتماد أو رفض أمر الصرف	لا صلاحية	قراءة عمليات الاعتماد
مسؤول إدارة الهوية	لا صلاحية	لا صلاحية	لا صلاحية	لا صلاحية	إنشاء الحساب وإعادة تعيين كلمة المرور	قراءة سجلات المصادقة فقط

قيد إلزامي: لا يمنح الدوران «موظف المالية» و«المعتمد المالي» للحساب نفسه. تخضع الصلاحيات لمبدأ أقل الامتيازات والحاجة إلى المعرفة.
 مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- ◀ يدون دور المعتمد المالي بقراءة الاسم الوظيفي فقط، ثم يمنح قراءة الأوامر المرسله واعتماد أمر الصرف أو رفضه.
- ◀ يدون دور مسؤول إدارة الهوية بلا صلاحية لبيانات الموظفين أو الحضور، ويقتصر عمله على إنشاء الحساب وإعادة تعيين كلمة المرور.
- ◀ يمنع هذا الفصل مسؤول الهوية من التدخل في العمليات المالية أو اعتمادها.

الخطوة 3 من 3: إضافة المراجعة المستقلة

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان - المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

المستند: مصفوفة التحكم في الوصول لمنصة الموارد البشرية

مصفوفة التحكم في الوصول لمنصة الموارد البشرية

إصدار تشغيلي بتاريخ 12-04-2026 لمنصة الحضور والعمليات المالية المصغرة

الدور	سجلات الموظفين	بيانات الحضور	أوامر الصرف	اعتماد الصرف	حسابات المستخدمين	سجل التدقيق
موظف الموارد البشرية	إنشاء وتعديل بيانات العمل	قراءة وتعديل سجلات الحضور	لا صلاحية	لا صلاحية	لا صلاحية	لا صلاحية
موظف المالية	قراءة الاسم الوظيفي فقط	لا صلاحية	إنشاء وإرسال أمر الصرف	لا صلاحية	لا صلاحية	لا صلاحية
المعتمد المالي	قراءة الاسم الوظيفي فقط	لا صلاحية	قراءة الأوامر المرسله	اعتماد أو رفض أمر الصرف	لا صلاحية	قراءة عمليات الاعتماد
مسؤول إدارة الهوية	لا صلاحية	لا صلاحية	لا صلاحية	لا صلاحية	إنشاء الحساب وإعادة تعيين كلمة المرور	قراءة سجلات المصادقة فقط
مراجع التدقيق الداخلي	قراءة دون تعديل	قراءة دون تعديل	قراءة دون تعديل	قراءة دون تعديل	لا صلاحية	قراءة جميع السجلات دون تعديل

قيد إلزامي: لا يمنح الدوران «موظف المالية» و«المعتمد المالي» للحساب نفسه، تخضع الصلاحيات لمبدأ أقل الامتيازات والحاجة إلى المعرفة.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- ◀ يدون دور مراجع التدقيق الداخلي بصلاحية قراءة دون تعديل لسجلات الموظفين والحضور وأوامر الصرف وعمليات الاعتماد.
- ◀ لا يمنح المراجع صلاحية إدارة حسابات المستخدمين أو تعديل السجلات.
- ◀ يكتمل النموذج بتوزيع الإنشاء والاعتماد والإدارة والمراجعة بين أدوار مستقلة، مما يدعم المحاسبة ويحد من احتمال إساءة الاستخدام أو الخطأ غير المكتشف.



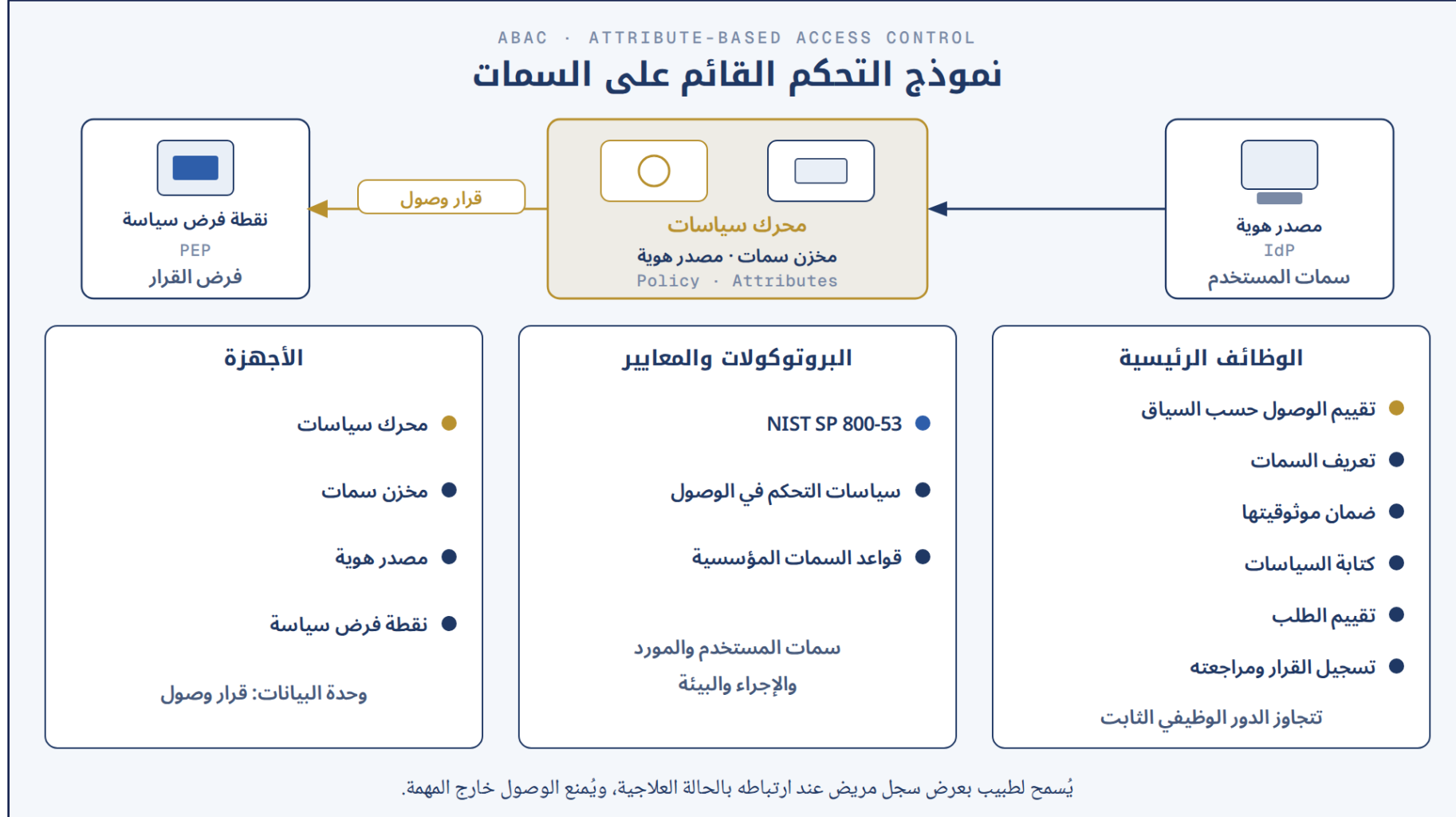
نموذج التحكم القائم على السمات (ABAC)



- ◀ التحكم القائم على السمات يتخذ قرار الوصول وفق سمات المستخدم والموارد والإجراء والبيئة وسياسات تربط بينها.
- ◀ وظيفته دعم قرارات دقيقة وسياقية تتجاوز الدور الوظيفي الثابت عند الحاجة.
- ◀ **الوظيفة:** تقييم الوصول حسب السياق والسمات.
- ◀ **المسؤوليات:** تعريف السمات، ضمان موثوقيتها، كتابة السياسات، تقييم الطلب، تسجيل القرار ومراجعته.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، سياسات التحكم في الوصول، قواعد السمات المؤسسية.
- ◀ **الأجهزة:** محرك سياسات، مخزن سمات، مصدر هوية، نقطة فرض سياسة.
- ◀ **وحدة البيانات:** قرار وصول ناتج عن تقييم سياسة وسياق.
- ◀ **مثال:** يسمح لطبيب بعرض سجل مريض عند ارتباطه بالحالة العلاجية، ويمنع الوصول خارج المهمة.



نموذج التحكم القائم على السمات (ABAC) (الشكل)





مقارنة نماذج التحكم في الوصول



النموذج	أساس منح الصلاحية	ميزة تصميمية	قيد معماري	حالة ملائمة
DAC	قرار مالك المورد	مرونة المشاركة	احتمال اتساع المشاركة	مستندات عمل محددة
MAC	تصنيف وسياسة مركزية	ضبط مركزي قوي	مرونة أقل للمالك	بيانات مصنفة
RBAC	الدور الوظيفي	سهولة الإدارة	أدوار واسعة أو كثيرة	منصة موارد بشرية
ABAC	السمات والسياق	دقة عالية	حوكمة السمات	وصول سياقي حساس

يختار المصمم النموذج وفق حساسية المورد وطبيعة العمل وقابلية المراجعة، لا وفق سهولة الإعداد وحدها.



الحاجة إلى المعرفة قيد إضافي على الوصول، فلا يكفي انتماء المستخدم إلى جهة أو دور محدد.

يجب أن يحتاج فعلاً إلى البيانات أو العملية لأداء مهمته المعينة. يكمل هذا القيد نموذج RBAC عندما تكون صلاحيات الدور أوسع من حاجة المهمة اليومية. في المصفوفة، يقرأ موظف المالية الاسم الوظيفي فقط ولا يصل إلى سجل الحضور.



إدارة الهوية (Identity Management)

- ◀ إدارة الهوية تشمل إنشاء الهوية وربطها بسمات موثوقة وتحديثها وإيقافها أو حذفها وفق دورة حياة منظمة.
- ◀ وظيفتها إبقاء الهوية والصلاحيات متوافقة مع الواقع الوظيفي.
- ◀ **الوظيفة:** إدارة صلاحية الهوية عبر دورة العمل.
- ◀ **المسؤوليات:** إنشاء الهوية، ربط السمات، تحديث الدور، إيقاف الحساب، مراجعة الصلاحيات.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، NIST SP 800-63-4، الضوابط الأساسية للأمن السيبراني.
- ◀ **الأجهزة:** مزود هوية، دليل مستخدمين، خدمة أدوار، واجهة إدارة الحسابات.
- ◀ **وحدة البيانات:** حساب نشط أو معدل أو موقوف.
- ◀ **مثال:** ينشئ مسؤول إدارة الهوية الحساب ويعيد تعيين كلمة المرور دون منحه صلاحيات مالية.



(الشكل) (Identity Management) إدارة الهوية



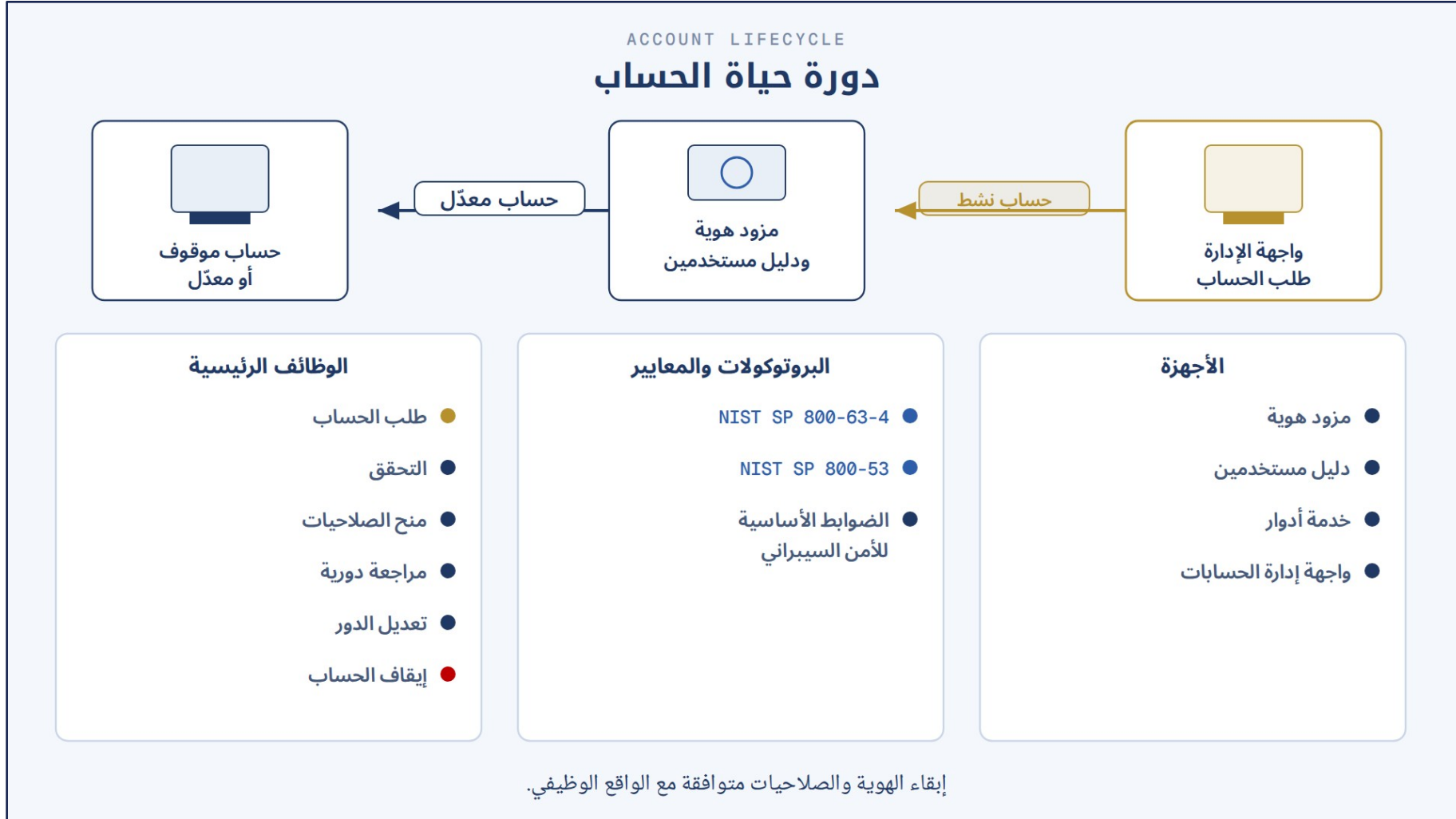


دورة حياة الحساب (Account Lifecycle)

- ◀ دورة حياة الحساب مسار منظم يبدأ بطلب الحساب والتحقق، ثم منح الصلاحيات ومراجعتها وتعديلها أو إيقافها عند انتهاء الحاجة.
- ◀ **الوظيفة:** إبقاء الهوية والصلاحيات متوافقة مع الواقع الوظيفي.
- ◀ **المسؤوليات:** طلب الحساب، التحقق، منح الصلاحيات، مراجعة دورية، تعديل الدور، إيقاف الحساب.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، NIST SP 800-63-4، الضوابط الأساسية للأمن السيبراني.
- ◀ **الأجهزة:** مزود هوية، دليل مستخدمين، خدمة أدوار، واجهة إدارة الحسابات.
- ◀ **وحدة البيانات:** حساب نشط أو معدل أو موقوف.
- ◀ **مثال:** تعدل المنشأة صلاحية الموظف عند انتقاله من دور تشغيلي إلى دور مراجعة.



دورة حياة الحساب (Account Lifecycle) (الشكل)





خصص 10 دقائق لرسم مسار حساب موظف ينتقل من موظف مالية إلى مراجع تدقيق داخلي.

حدد في كل مرحلة من يطلب التعديل، وما الصلاحيات التي تزال، وما السجل الذي يثبت القرار. تحقق من أن الحساب لا يحتفظ بصلاحيات إنشاء أمر صرف أو اعتماده بعد انتقاله إلى دور المراجعة.



- ◀ التشفير المتماثل يستخدم مفتاحاً سرياً مشتركاً للتشفير وفك التشفير في النموذج المفاهيمي العام.
- ◀ وظيفته حماية سرية البيانات في التخزين أو النقل وفق تصميم يحمي المفتاح.
- ◀ **الوظيفة:** حماية سرية المحتوى بكفاءة.
- ◀ **المسؤوليات:** اختيار الاستخدام، حماية المفتاح، توزيع المفتاح، تدوير المفتاح، تقييد الوصول إليه.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، NIST SP 800-57 Part 1 Rev. 5، سياسات إدارة المفاتيح.
- ◀ **الأجهزة:** خدمات إدارة مفاتيح، مخازن أسرار، وحدات حماية مفاتيح، مكتبات تشفير معتمدة.
- ◀ **وحدة البيانات:** نص صريح ونص مشفر ومفتاح مناسب.
- ◀ **مثال:** تحفظ نسخة ملف رواتب في التخزين السحابي بعد تشفيرها بمفتاح محفوظ في خدمة إدارة مفاتيح.



التشفير المتماثل (الشكل)

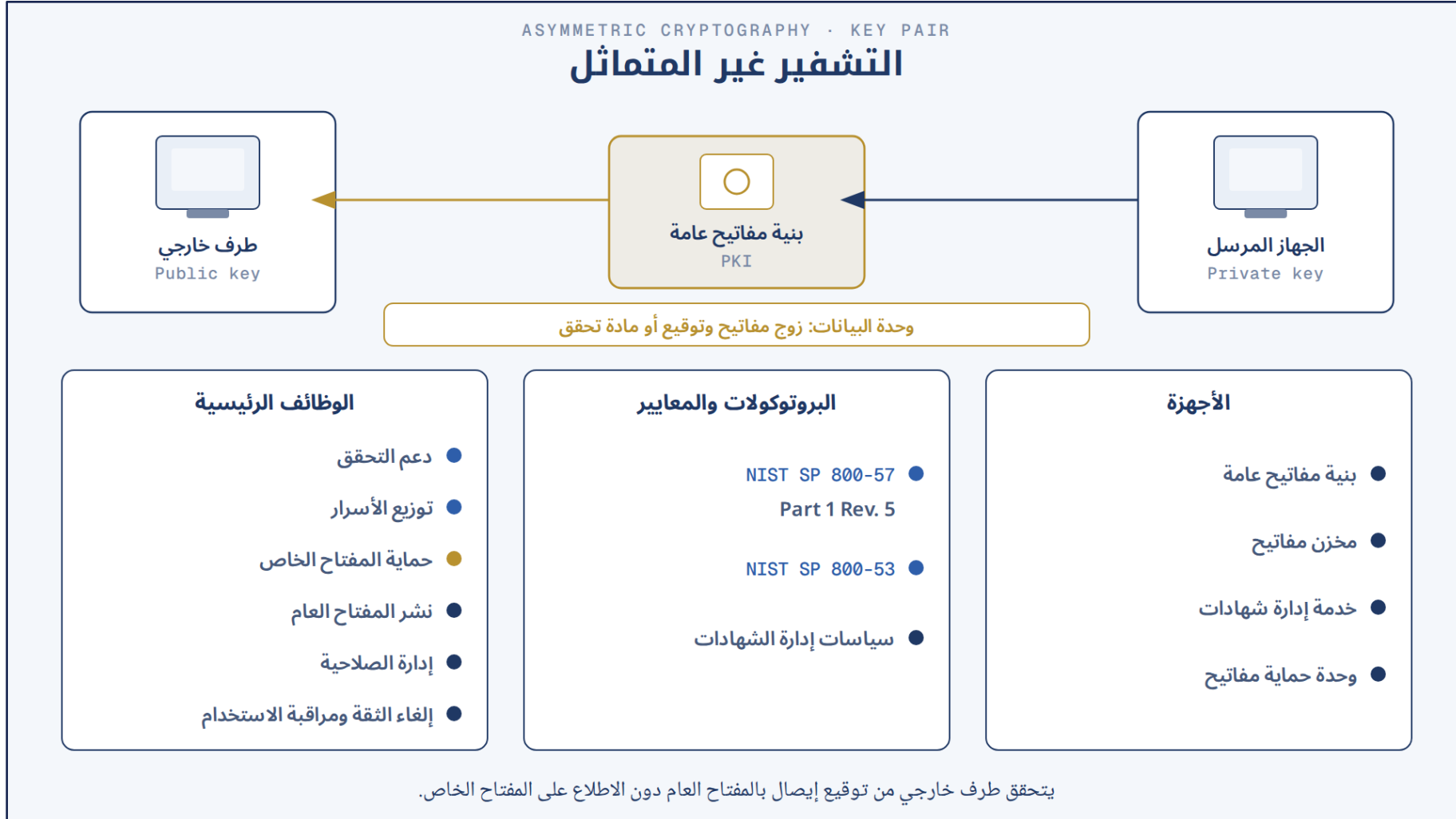




- ◀ التشفير غير المتماثل يعتمد على زوج مفاتيح عام وخاص مترابطين في النموذج المفاهيمي.
- ◀ وظيفته دعم حالات مثل توزيع الأسرار بصورة محكمة أو التوقيع الرقمي وفق نموذج الثقة المطلوب.
- ◀ **الوظيفة:** دعم التحقق وتوزيع الأسرار.
- ◀ **المسؤوليات:** حماية المفتاح الخاص، نشر المفتاح العام، إدارة الصلاحية، إلغاء الثقة، مراقبة الاستخدام.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53, NIST SP 800-57 Part 1 Rev. 5, سياسات إدارة الشهادات.
- ◀ **الأجهزة:** بنية مفاتيح عامة، مخزن مفاتيح، خدمة إدارة شهادات، وحدة حماية مفاتيح.
- ◀ **وحدة البيانات:** زوج مفاتيح وتوقيع أو مادة تحقق.
- ◀ **مثال:** يتحقق طرف خارجي من توقيع إيصال بالمفتاح العام دون الاطلاع على المفتاح الخاص.



التشفير غير المتماثل (الشكل)

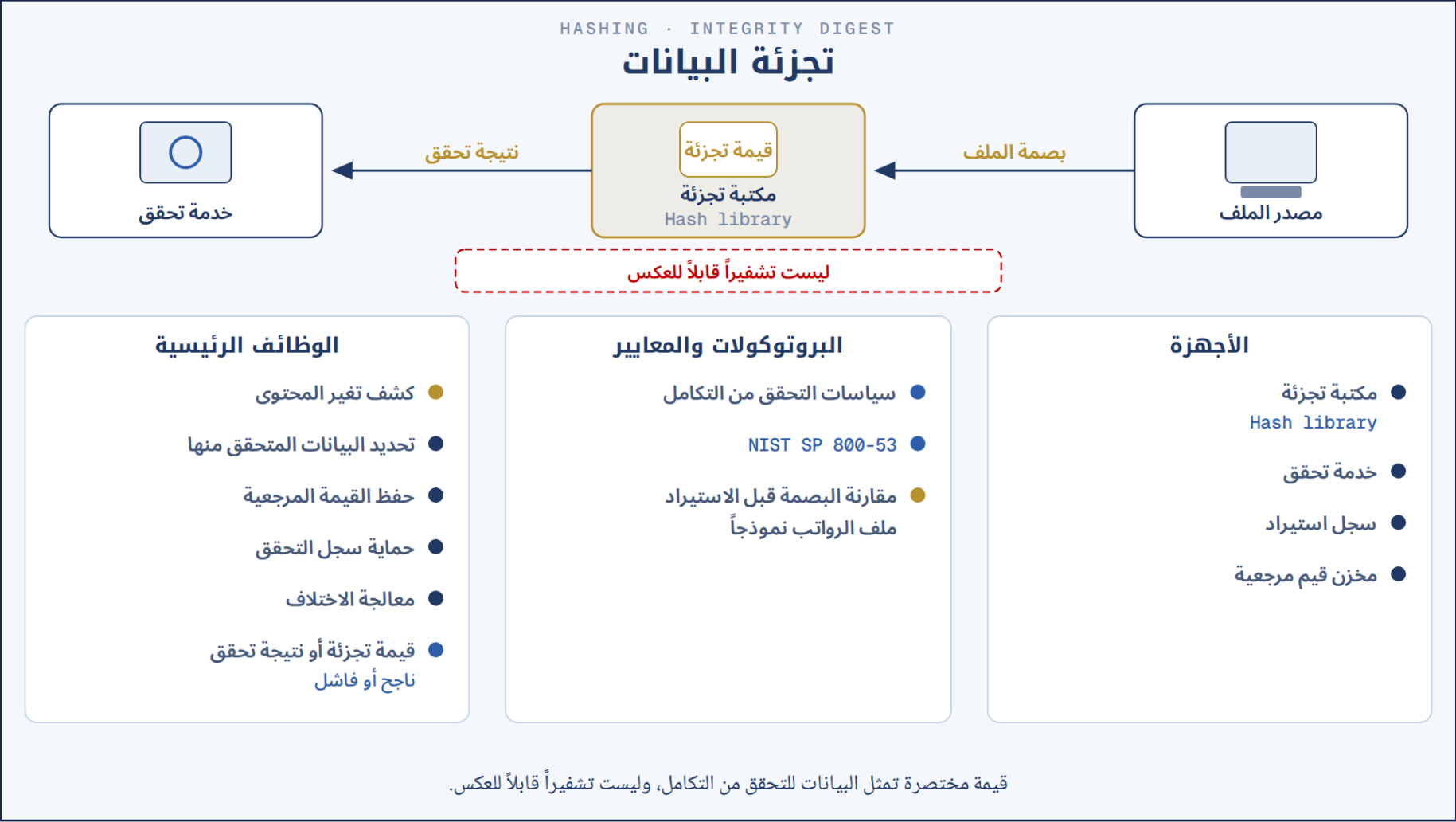




- ◀ تجزئة البيانات دالة تنتج قيمة مختصرة تمثل البيانات، وتستخدم للتحقق من تكامل البيانات أو في تصميمات حماية كلمات المرور المناسبة، ولا تعد تشفيراً قابلاً للعكس.
- ◀ **الوظيفة:** كشف تغير المحتوى عند مقارنة القيم.
- ◀ **المسؤوليات:** تحديد البيانات المتحقق منها، حفظ القيمة المرجعية، حماية سجل التحقق، معالجة الاختلاف.
- ◀ **البروتوكولات والمعايير:** سياسات التحقق من تكامل البيانات، NIST SP 800-53.
- ◀ **الأجهزة:** مكتبة تجزئة، خدمة تحقق، سجل استيراد، مخزن قيم مرجعية.
- ◀ **وحدة البيانات:** قيمة تجزئة أو نتيجة تحقق ناجح أو فاشل.
- ◀ **مثال:** تقارن المنصة بصمة ملف الرواتب المحفوظة بالبصمة الجديدة قبل الاستيراد.



تجزئة البيانات (Hashing) (الشكل)





خصص 10 دقائق لتحليل اختلاف بصمة SHA-256 لملف رواتب عن البصمة المحفوظة في سجل الاستيراد.

اكتب قراراً من ثلاث خطوات: وقف الاستيراد، والتحقق من مصدر الملف، وتوثيق نتيجة المراجعة. بين لماذا لا يحل التشفير محل هذه المقارنة عندما يكون الهدف المباشر كشف تغير المحتوى.

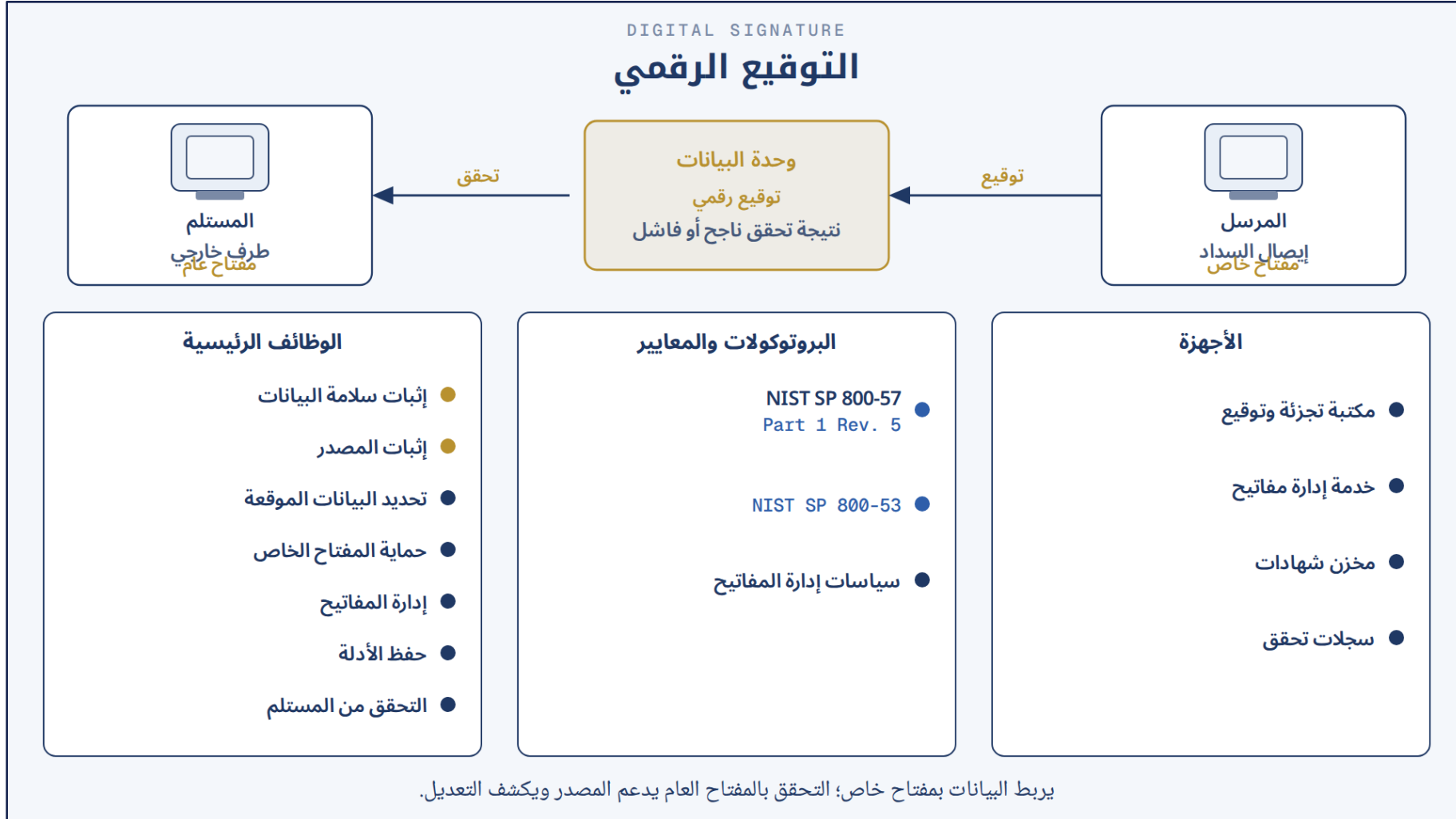


(Digital Signature) التوقيع الرقمي

- ◀ التوقيع الرقمي آلية تربط البيانات بمفتاح خاص للتحقق من المصدر وسلامة البيانات باستخدام مفتاح عام مناسب.
- ◀ وظيفته دعم التحقق من المصدر وكشف التعديل ضمن نموذج ثقة يحمي المفتاح الخاص.
- ◀ **الوظيفة:** إثبات سلامة البيانات ومصدرها.
- ◀ **المسؤوليات:** تحديد البيانات الموقعة، حماية المفتاح الخاص، إدارة المفاتيح، حفظ الأدلة، التحقق من المستلم.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، NIST SP 800-57 Part 1 Rev. 5، سياسات إدارة المفاتيح.
- ◀ **الأجهزة:** مكتبة تجزئة وتوقيع، خدمة إدارة مفاتيح، مخزن شهادات، سجلات تحقق.
- ◀ **وحدة البيانات:** توقيع رقمي أو نتيجة تحقق ناجح أو فاشل.
- ◀ **مثال:** يوقع إيصال السداد رقمياً ليتمكن الطرف الخارجي من التحقق بالمفتاح العام.

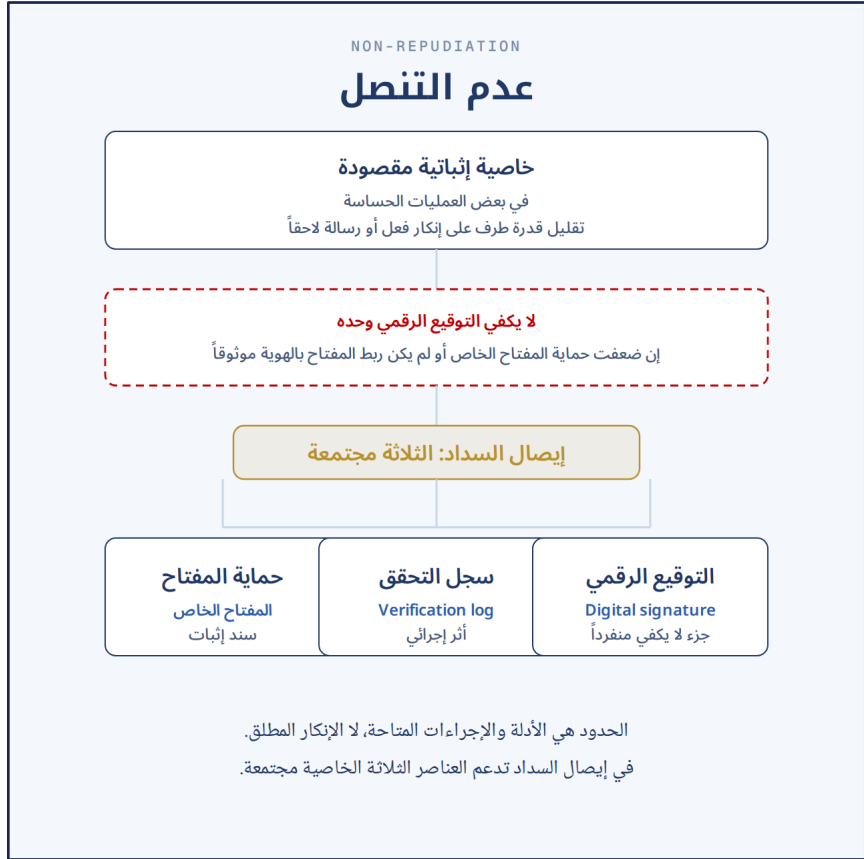


التوقيع الرقمي (Digital Signature) (الشكل)





عدم التنصل (Non-repudiation)



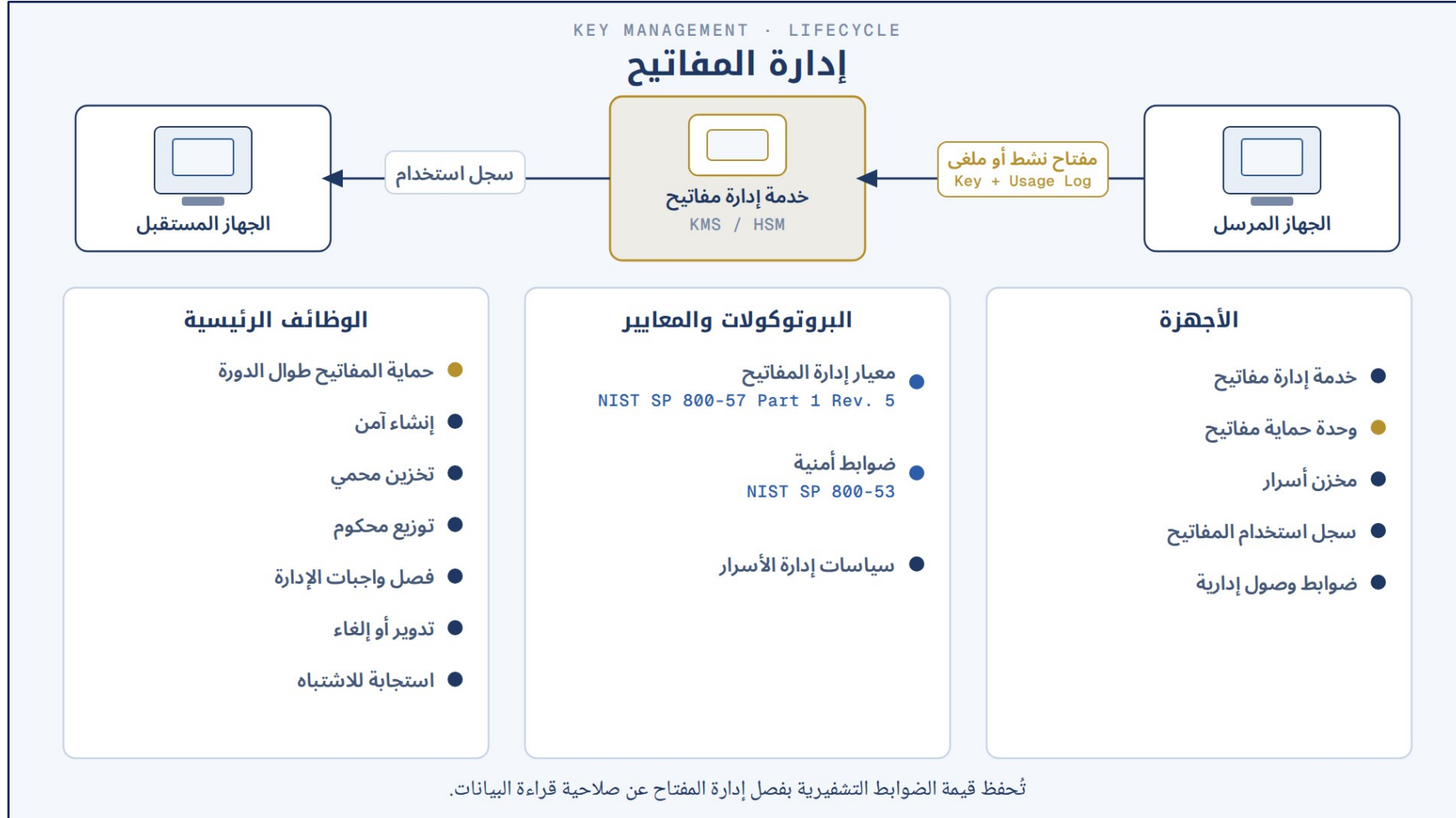
- ◀ عدم التنصل خاصية إثباتية مقصودة في بعض العمليات الحساسة، تهدف إلى تقليل قدرة طرف على إنكار فعل أو رسالة لاحقاً ضمن حدود الأدلة والإجراءات المتاحة.
- ◀ لا يكفي التوقيع الرقمي وحده إذا ضعفت حماية المفتاح الخاص أو لم يكن ربط المفتاح بالهوية موثقاً.
- ◀ في إيصال السداد، تدعم حماية المفتاح وسجل التحقق والتوقيع الرقمي هذه الخاصية مجتمعة.



- ◀ إدارة المفاتيح هي حوكمة دورة حياة المفاتيح من الإنشاء والحماية والتوزيع إلى الاستخدام والتدوير والإلغاء أو الإتلاف.
- ◀ وظيفتها المحافظة على قيمة الضوابط التشفيرية.
- ◀ **الوظيفة:** حماية المفاتيح طوال دورة حياتها.
- ◀ **المسؤوليات:** إنشاء آمن، تخزين محمي، توزيع محكوم، فصل واجبات الإدارة، تدوير أو إلغاء، استجابة للاشتباه.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، NIST SP 800-57 Part 1 Rev. 5، سياسات إدارة الأسرار.
- ◀ **الأجهزة:** خدمة إدارة مفاتيح، مخزن أسرار، وحدة حماية مفاتيح، سجل استخدام المفاتيح، ضوابط وصول إدارية.
- ◀ **وحدة البيانات:** مفتاح نشط أو معطل أو ملغى وسجل استخدام.
- ◀ **مثال:** يفصل النظام إدارة مفتاح قاعدة البيانات عن صلاحية قراءة بيانات الرواتب.



إدارة المفاتيح (Key Management) (الشكل)



تقرير حادثة تعرض مفتاح تشفير

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية

جازان، المملكة العربية السعودية

الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

النموذج: تقرير حادثة أمنية

تقرير حادثة أمنية

رقم الحادثة:INC-2026-0416-07

تاريخ ووقت الاكتشاف:11:26 2026-04-16

النظام المتأثر:بيئة الاختبار لمنصة الموارد البشرية الداخلية

تصنيف الحادثة:تعرض محتمل لمادة تشفير في ملف إعدادات

وصف الواقعة:أظهر فحص آلي لمستودع الشيفرة وجود مرجع لمفتاح التوقيع الخاص بإيصالات السداد التجريبية داخل ملف إعدادات مرفوع إلى فرع اختبار محدود الصلاحية.

الأصل المتأثر:مفتاح توقيع رقمي مخصص لبيئة الاختبار وبيانات إعدادات خدمة الإيصالات

الأثر المحتمل:قد يتمكن من حصل على المادة المكشوفة من إنشاء توقيعات اختبار غير موثوقة، مما يضعف التحقق من المصدر والتكامل في البيئة المتأثرة. لا توجد دلالة على تأثير بيئة الإنتاج.

إجراء الاحتواء الفوري:تعطيل المفتاح المتأثر، إزالة الملف من فرع الاختبار، إبطال النسخ المؤقتة، ومراجعة سجل الوصول إلى المستودع.

إجراء المعالجة:توليد زوج مفاتيح جديد داخل خدمة إدارة مفاتيح، حفظ المفتاح الخاص خارج ملفات الإعدادات، وتحديث الخدمة لاستخدام مرجع سرّي محمي.

إجراء الوقاية:تفعيل فحص الأسرار قبل دمج الشيفرة، منع رفع ملفات الإعدادات الحساسة، وتنبيه فريق التطوير عند اكتشاف نمط مفتاح أو رمز وصول.

حالة الحادثة:محتوى قيد التحقق بعد تدوير المفتاح ومراجعة السجلات بتاريخ 17-04-2026

لا يتضمن التقرير قيمة المفتاح أو أي مادة سرية. تستخدم النتائج في اختبار ضوابط إدارة المفاتيح والمراقبة والكشف.

مقدم الطلب

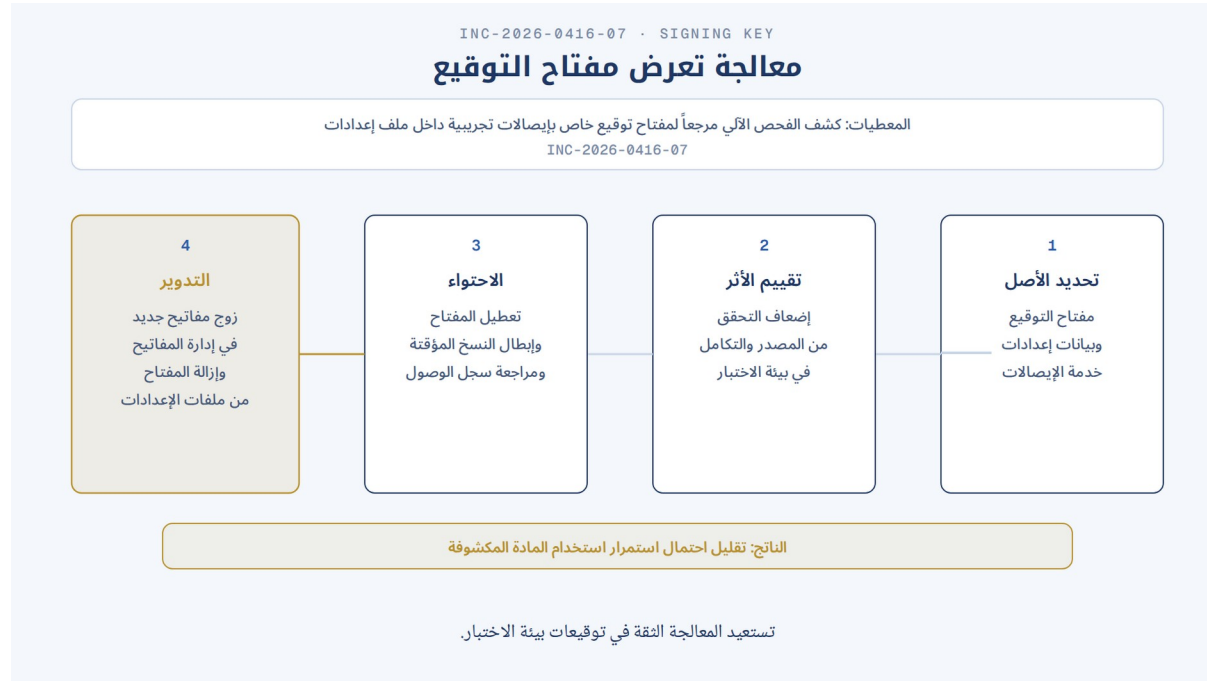
المسؤول

الاعتماد

مستند تخطيطي إلكتروني، الأسماء والأرقام غير حقيقية

- ▶ اقرأ رقم الحادثة INC-2026-0416-07 وحدد الأصل المتأثر والأثر المحتمل وإجراء المعالجة.
- ▶ يشير التقرير إلى تعرض محتمل لمفتاح توقيع خاص ببيئة اختبار، ولا يشير إلى تأثير بيئة الإنتاج.
- ▶ تتضمن المعالجة تعطيل المفتاح وتوليد زوج جديد وحفظ المفتاح الخاص خارج ملفات الإعدادات، ثم مراجعة سجلات الوصول وتفعيل فحص الأسرار.

مثال محلول، معالجة تعرض مفتاح التوقيع



المعطيات: كشف الفحص الآلي مرجعاً لمفتاح توقيع خاص بإيصالات تجريبية داخل ملف إعدادات في الحادثة INC-2026-0416-07.

الخطوات:

النتائج: تقلل المعالجة احتمال استمرار استخدام المادة المكشوفة وتستعيد الثقة في توقيعات بيئة الاختبار.

يولد زوج مفاتيح جديداً داخل خدمة إدارة مفاتيح ويزيل المفتاح من ملفات الإعدادات.

٤

يعطل المفتاح المتأثر ويبطل النسخ المؤقتة ويراجع سجل الوصول.

٣

يقيم الأثر المحتمل بوصفه إضعافاً للتحقق من المصدر والتكامل في بيئة الاختبار.

٢

يحدد الأصل المتأثر بأنه مفتاح التوقيع وبيانات إعدادات خدمة الإيصالات.

١



جدول قرارات التشفير وتكامل البيانات

حالة الاستخدام	الهدف الأمني	الآلية المناسبة	حماية المفتاح أو القيمة
نسخة ملف رواتب في التخزين السحابي	السرية أثناء السكون	تشفير متماثل للملف	مفتاح في خدمة إدارة مفاتيح
فحص تعديل ملف رواتب	كشف التعديل	تجزئة SHA-256 للملف	بصمة محفوظة مع سجل الاستيراد
إيصال سداد لطرف خارجي	التكامل وعدم التنصل والتحقق العام	توقيع رقمي لبصمة الإيصال	مفتاح خاص محمي ومفتاح عام متاح
تبادل ملف رواتب مع خدمة معتمدة	سرية المحتوى وحماية مفتاح الجلسة	تشفير هجين	مفتاح جلسة ومفتاح عام للمستلم

تشفير هجين يجمع كفاءة التشفير المتماثل للملف مع استخدام المفتاح العام للمستلم لحماية مفتاح الجلسة.

قرارات التشفير وتكامل البيانات

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

سجل قرارات حماية البيانات والتكامل

قرارات تصميمية مرتبطة بمنصة الخدمات السحابية وإصالات السداد الإلكترونية

حالة الاستخدام	الهدف الأمني	الآلية المعتمدة	إدارة المفاتيح أو القيم	الضمانة المتحققة	سبب القرار
حفظ نسخة ملف رواتب مشفرة في التخزين السحابي	السرية أثناء السكون	تشفير متماثل للملف	مفتاح تشفير محفوظ في خدمة إدارة مفاتيح مع تدوير دوري	سرية المحتوى	التشفير المتماثل مناسب للملفات الكبيرة ويقلل كلفة المعالجة.
فحص تعديل ملف رواتب قبل استيراده	كشف التعديل	تجزئة SHA-256 للملف	بصمة تجزئة محفوظة مع سجل الاستيراد	تكامل البيانات وكشف التغيير	التجزئة تكشف اختلاف المحتوى لكنها وحدها لا تثبت هوية الجهة المرسلة.
إصدار إيصال سداد إلكتروني قابل للتحقق من جهة خارجية	التكامل وعدم التنصل والتحقق العام	توقيع رقمي لبصمة الإيصال	المفتاح الخاص داخل خدمة إدارة مفاتيح والمفتاح العام متاح للتحقق	تكامل وعدم تنصل والتحقق من المصدر العام	لا يشارك المفتاح الخاص مع جهة التحقق، ويمكن التحقق بالمفتاح العام.
تبادل ملف رواتب مع خدمة سحابية معتمدة	سرية المحتوى وحماية مفتاح الجلسة	تشفير هجين	مفتاح جلسة متماثل للملف ومفتاح عام للمستلم لحماية مفتاح الجلسة	سرية أثناء النقل	يجمع بين كفاءة التشفير المتماثل وسهولة توزيع المفاتيح العامة.
معالجة تعرض مفتاح توقيع الاختبار في الحادثة INC-2026-0416-07	منع إساءة استعمال المفتاح المكشوف	إبطال المفتاح وتوليد زوج مفاتيح جديد	حفظ المفتاح الخاص خارج مستودع الشيفرة وتفعيل سجل استخدام المفتاح	استعادة الثقة في التوقيع وتقليل أثر التعرض	تغيير المفتاح فقط دون إبطال المفتاح المكشوف يترك احتمال استخدامه قائماً.

تستخدم الفواتير أو الإصالات الإلكترونية في المملكة ضريبة قيمة مضافة بنسبة 15% عند انطباقها، وتستلزم الفاتورة الضريبية المبسطة رمز استجابة سريعة وفق متطلبات هيئة الزكاة والضريبة والجمارك.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- أبدأ من الهدف الأمني في كل صف.
- تستخدم نسخة ملف الرواتب تشفيراً متماثلاً لتحقيق السرية أثناء السكون.
- تستخدم عملية فحص التعديل تجزئة SHA-256 لكشف تغير الملف.
- يستخدم إيصال السداد توقيعاً رقمياً للتحقق العام والتكامل وعدم التنصل.
- ويستخدم تبادل ملف الرواتب تشفيراً هجيناً لحماية المحتوى ومفتاح الجلسة معاً.

مثال محلول، اختيار حماية إيصال سداد إلكتروني



- المعطيات: يحتاج إيصال سداد إلكتروني إلى تكامل وعدم تنصل وتحقيق قابل للتحقق من جهة خارجية دون مشاركة المفتاح الخاص.
- الخطوات:
- النتائج: يحقق القرار تكامل الإيصال والتحقق من مصدره وعدم التنصل ضمن حماية المفتاح والهوية والأدلة.

٤ تتيح المفتاح العام للتحقق من التوقيع دون كشف المادة السرية.

٣ تختار توقيعاً رقمياً لبصمة الإيصال مع حفظ المفتاح الخاص في خدمة إدارة مفاتيح.

٢ تستبعد التشفير المتماثل لأنه يتطلب مشاركة مفتاح سري مع جهة التحقق.

١ تستبعد التجزئة وحدها لأنها تكشف التعديل ولا تثبت هوية المصدر.



خصص 10 دقائق لملء جدول من ثلاثة صفوف يربط ملف الرواتب وإيصال السداد وتبادل الملف السحابي بالهدف الأمني والآلية وإدارة المفتاح أو القيمة.

راجع قراراتك مقابل الجدول السابق، ثم اكتب سبباً واحداً لرفض التجزئة وحدها عندما تحتاج جهة خارجية إلى التحقق من مصدر الإيصال.

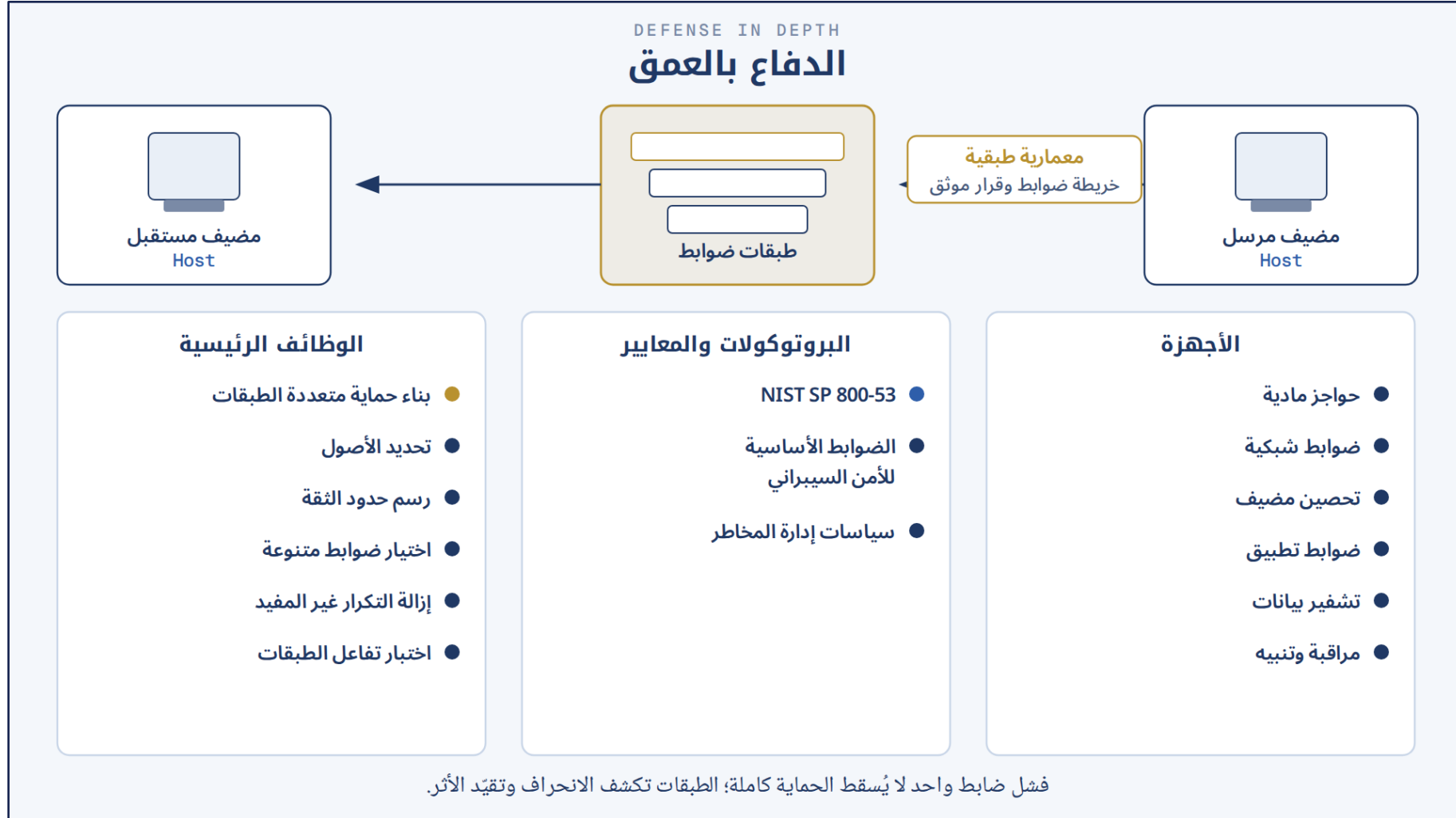


الدفاع بالعمق (Defense in Depth)

- ◀ الدفاع بالعمق نهج يوزع ضوابط متكاملة عبر طبقات متعددة بحيث لا يؤدي فشل ضابط واحد إلى فقدان الحماية كاملة.
- ◀ وظيفته تقليل فرص النجاح الهجومي وكشف الانحرافات وتقييد الأثر.
- ◀ **الوظيفة:** بناء حماية متعددة الطبقات.
- ◀ **المسؤوليات:** تحديد الأصول، رسم حدود الثقة، اختيار ضوابط متنوعة، إزالة التكرار غير المفيد، اختبار تفاعل الطبقات.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، سياسات إدارة المخاطر.
- ◀ **الأجهزة:** حواجز مادية، ضوابط شبكية، تحصين مضيف، ضوابط تطبيق، تشفير بيانات، مراقبة وتنبيه.
- ◀ **وحدة البيانات:** معمارية طبقية وخريطة ضوابط وقرار موثق.
- ◀ **مثال:** تجمع المنصة مصادقة متعددة العوامل و RBAC وتشفيراً وسجلات مراقبة وتقسيماً شبكياً.



الدفاع بالعمق (Defense in Depth) (الشكل)

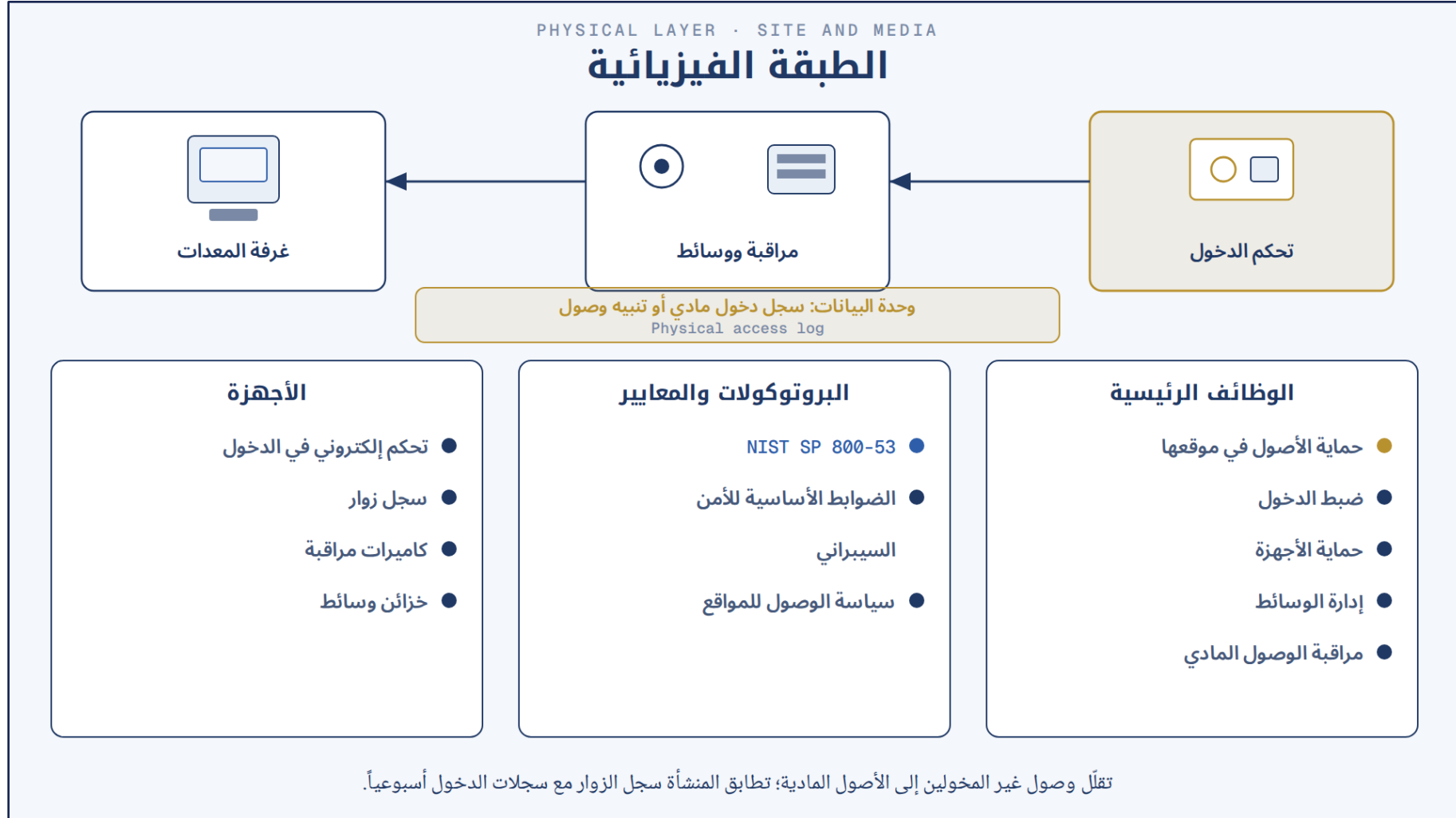




- ◀ الطبقة الفيزيائية تحمي المواقع والمعدات ووسائل التخزين من الدخول أو العبث المادي غير المصرح.
- ◀ وظيفتها تقليل وصول غير المخولين إلى الأصول المادية.
- ◀ **الوظيفة:** حماية الأصول في موقعها.
- ◀ **المسؤوليات:** ضبط الدخول، حماية الأجهزة، إدارة الوسائل، مراقبة الوصول المادي.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، سياسة الوصول للمواقع.
- ◀ **الأجهزة:** تحكم إلكتروني في الدخول، سجل زوار، كاميرات مراقبة، خزائن وسائل.
- ◀ **وحدة البيانات:** سجل دخول مادي أو تنبيه وصول.
- ◀ **مثال:** تطابق المنشأة سجل الزوار مع سجلات الدخول إلى غرفة معدات الشبكة أسبوعياً.



الطبقة الفيزيائية (الشكل)





- ◀ طبقة الشبكة تنظم الاتصالات وحدود الثقة والمناطق الشبكية لتقييد التدفق غير الضروري.
- ◀ وظيفتها الحد من الاتصال غير المصرح به ومراقبة حركة الشبكة.
- ◀ **الوظيفة:** ضبط الاتصال بين المناطق.
- ◀ **المسؤوليات:** تقسيم المناطق، تقييد الاتصالات، مراقبة الحركة، مراجعة الحدود.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، قواعد الجدار الناري.
- ◀ **الأجهزة:** جدار حماية، نظام كشف ومنع التسلل، نقاط تقسيم الشبكة، منصة مراقبة شبكية.
- ◀ **وحدة البيانات:** تدفق اتصال مسموح أو مرفوض وتنبيه شبكي.
- ◀ **مثال:** تفصل المنشأة شبكة الضيوف عن شبكة الأنظمة الأكاديمية وتراجع قواعد الجدار الناري شهرياً.



طبقة الشبكة (الشكل)

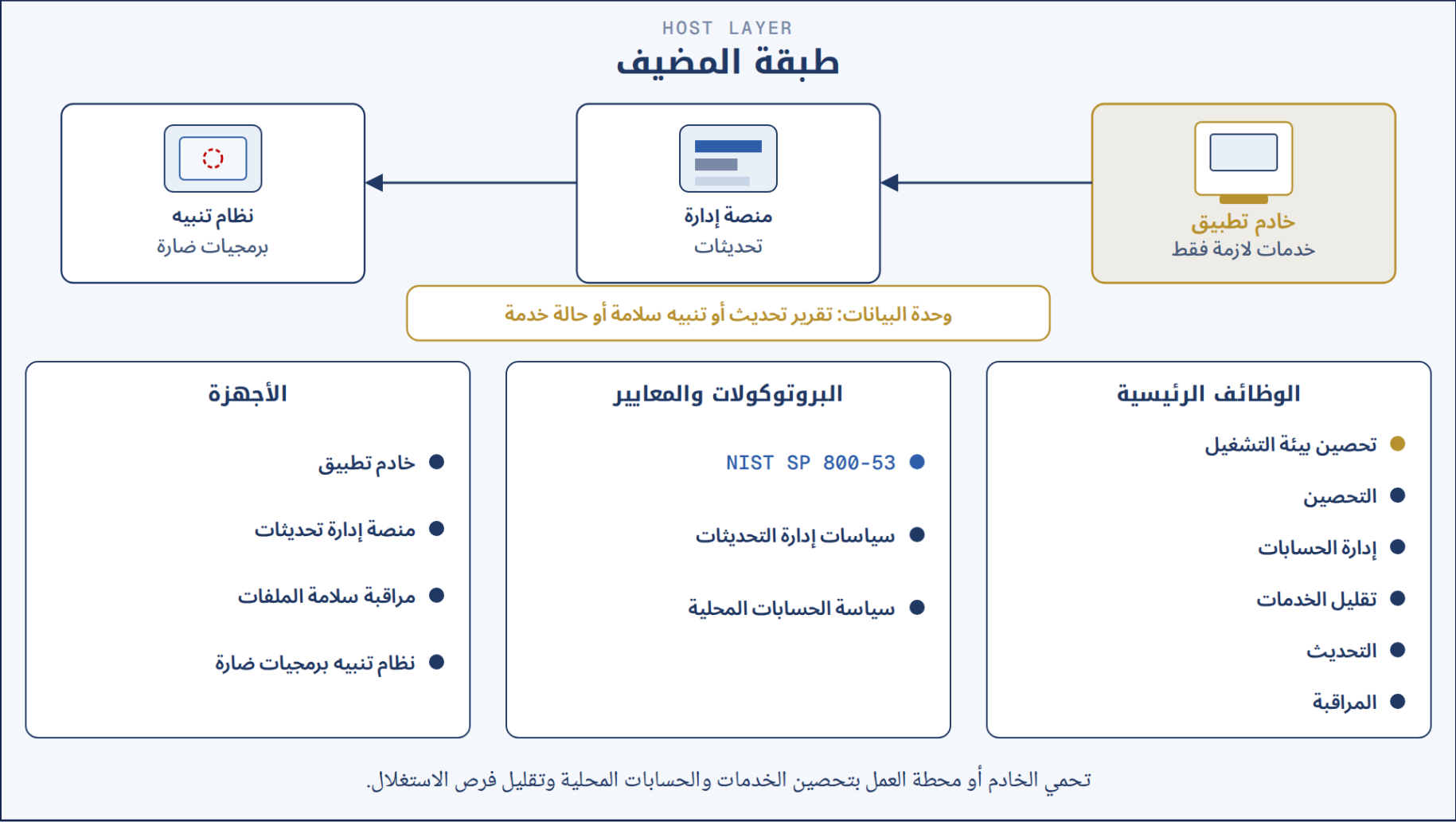




- ◀ طبقة المضيف تحمي الخادم أو محطة العمل ونظامها وخدماتها وحساباتها المحلية.
- ◀ وظيفتها تقليل فرص استغلال الخدمات غير الضرورية أو غير المحدثة.
- ◀ **الوظيفة:** تحصين بيئة التشغيل.
- ◀ **المسؤوليات:** التحصين، إدارة الحسابات، تقليل الخدمات، التحديث، المراقبة.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، سياسات إدارة التحديثات، سياسة الحسابات المحلية.
- ◀ **الأجهزة:** خادم تطبيق، منصة إدارة تحديثات، مراقبة سلامة الملفات، نظام تنبيه برمجيات ضارة.
- ◀ **وحدة البيانات:** تقرير تحديث أو تنبيه سلامة أو حالة خدمة.
- ◀ **مثال:** يشغل خادم التطبيق الخدمات اللازمة فقط، وتراجع المنشأة تقرير التحديثات الناجحة والثغرات المفتوحة.



طبقة المضيف (الشكل)

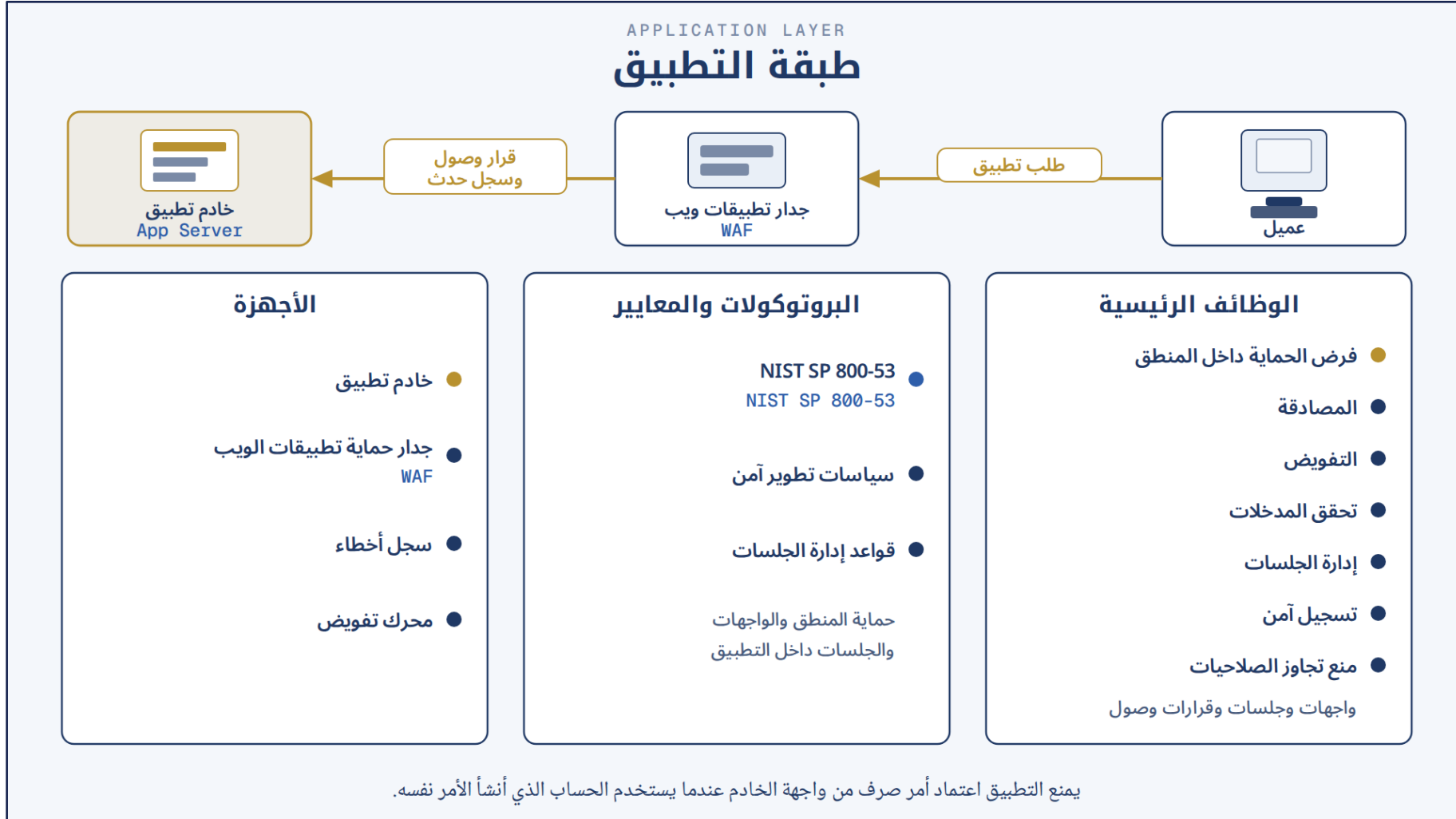




- ◀ طبقة التطبيق تحمي منطق التطبيق ووواجهاته وجلساته وقرارات الوصول داخله.
- ◀ وظيفتها منع تجاوز الصلاحيات وإدارة المدخلات والأخطاء والجلسات بصورة آمنة.
- ◀ **الوظيفة:** فرض الحماية داخل منطق التطبيق.
- ◀ **المسؤوليات:** المصادقة، التفويض، تحقق المدخلات، إدارة الجلسات، تسجيل آمن.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، سياسات تطوير آمن، قواعد إدارة الجلسات.
- ◀ **الأجهزة:** خادم تطبيق، جدار حماية تطبيقات الويب، سجل أخطاء، محرك تفويض.
- ◀ **وحدة البيانات:** طلب تطبيق وقرار وصول وسجل حدث.
- ◀ **مثال:** يمنع التطبيق اعتماد أمر صرف من واجهة الخادم عند استخدام حساب أنشأ الأمر نفسه.



طبقة التطبيق (الشكل)





- ◀ طبقة البيانات تحمي البيانات بحسب تصنيفها وحساسيتها خلال التخزين والمعالجة والنقل.
- ◀ وظيفتها المحافظة على السرية والتكامل والتوافر ضمن ضوابط وصول وإدارة مفاتيح.
- ◀ **الوظيفة:** حماية البيانات في دورة استخدامها.
- ◀ **المسؤوليات:** التصنيف، الوصول المقيد، التشفير، النسخ الاحتياطي، التحقق من التكامل.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53, NIST SP 800-57 Part 1 Rev. 5، الضوابط الأساسية للأمن السيبراني.
- ◀ **الأجهزة:** خدمة إدارة مفاتيح، مخزن أسرار، تشفير بيانات، مخزن نسخ احتياطي، سجل استخدام مفاتيح.
- ◀ **وحدة البيانات:** بيانات مصنفة أو نسخة مشفرة أو نتيجة تحقق تكامل.
- ◀ **مثال:** تشفير المنشأة نسخة احتياطية لسجلات الرواتب وتفصل إدارة المفتاح عن قراءة البيانات.



طبقة البيانات (الشكل)



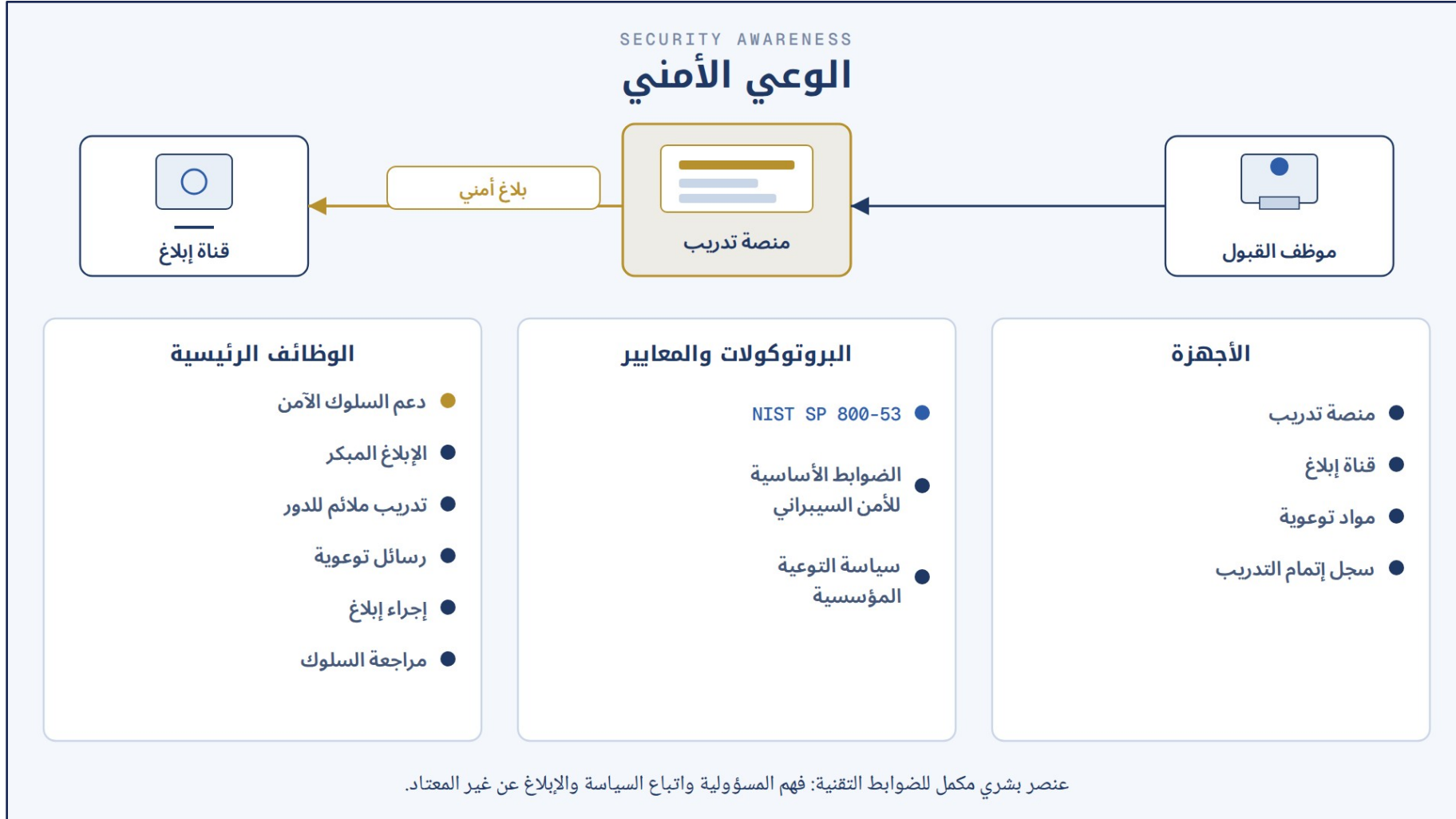


(Security Awareness) الوعي الأمني

- ◀ الوعي الأمني عنصر بشري مكمل للضوابط التقنية، يمكّن العاملين من فهم مسؤولياتهم واتباع السياسة والإبلاغ عن الحالات غير الطبيعية.
- ◀ **الوظيفة:** دعم السلوك الآمن والإبلاغ المبكر.
- ◀ **المسؤوليات:** تدريب ملائم للدور، رسائل توعوية، إجراء إبلاغ، مراجعة السلوك.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، سياسة التوعية المؤسسية.
- ◀ **الأجهزة:** منصة تدريب، قناة إبلاغ، مواد توعوية، سجل إتمام التدريب.
- ◀ **وحدة البيانات:** بلاغ أمني أو سجل إتمام توعية.
- ◀ **مثال:** يتحقق موظف القبول من طلب تعديل حساب حساس ويبلغ عن الطلب غير المعتاد عبر المسار المعتمد.



(الشكل) (Security Awareness) الوعي الأمني



خصص 11 دقيقة لصياغة بلاغ أمني مختصر عن طلب غير معتاد لتعديل حساب إداري.

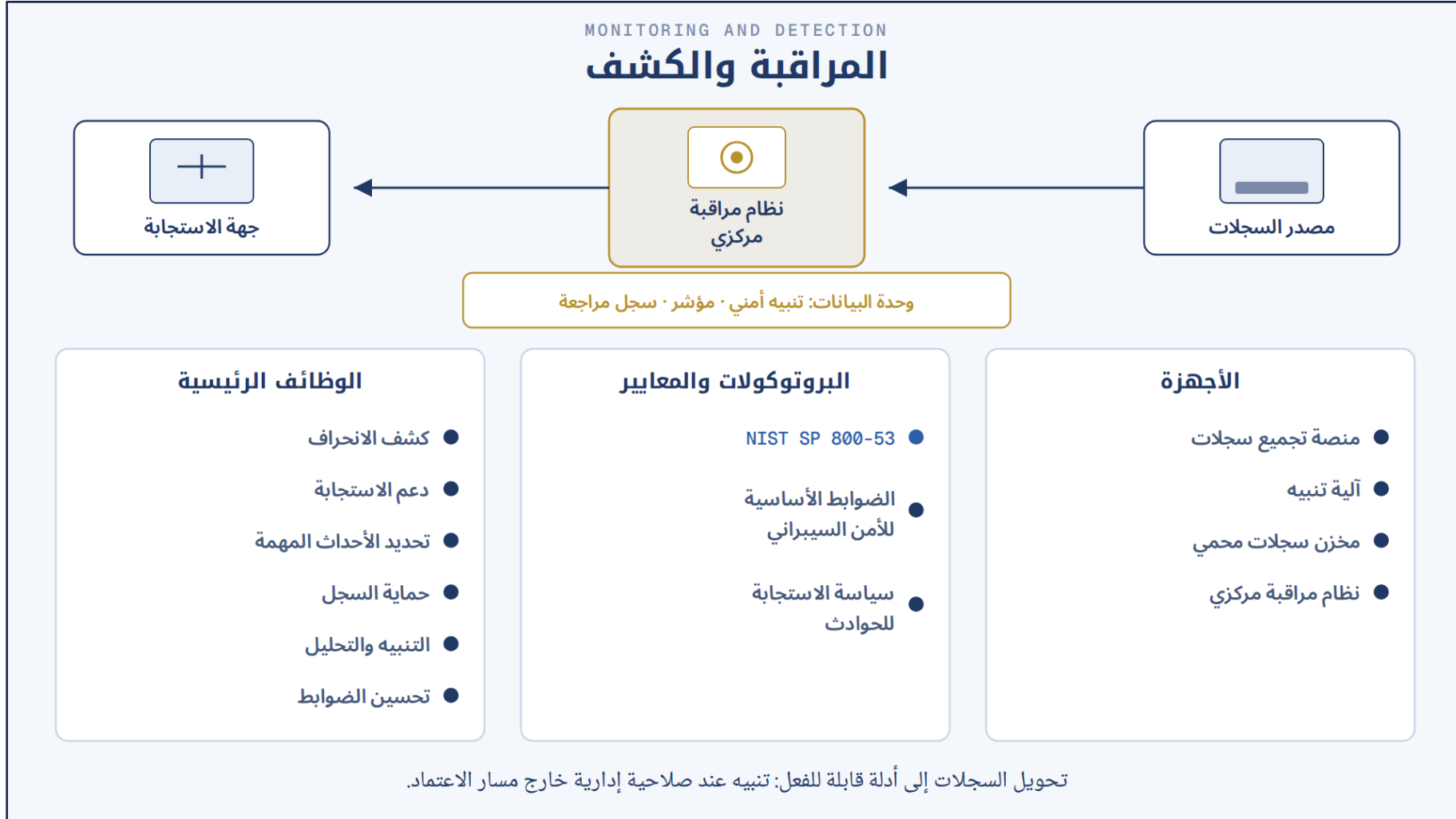
اذكر هوية مقدم الطلب كما ظهرت في الطلب، والعملية المطلوبة، وسبب الاشتباه، ومسار الإبلاغ الداخلي. لا تدرج كلمة مرور أو رمز وصول أو بيانات شخصية غير لازمة في البلاغ، لأن السجل والبلاغ يقتصران على السياق المشروع.



- ◀ المراقبة والكشف هما جمع مؤشرات وأحداث أمنية وتحليلها للتعرف على السلوك غير المعتاد أو انتهاكات السياسة ودعم الاستجابة والتحسين.
- ◀ وظيفتهما تحويل السجلات إلى أدلة قابلة للفعل.
- ◀ **الوظيفة:** كشف الانحراف ودعم الاستجابة.
- ◀ **المسؤوليات:** تحديد الأحداث المهمة، حماية السجل، التنبيه، التحليل، تحسين الضوابط.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53، الضوابط الأساسية للأمن السيبراني، سياسة الاستجابة للحوادث.
- ◀ **الأجهزة:** منصة تجميع سجلات، آلية تنبيه، مخزن سجلات محمي، نظام مراقبة مركزي.
- ◀ **وحدة البيانات:** تنبيه أمني أو مؤشر أو سجل مراجعة.
- ◀ **مثال:** ينبه النظام عند منح صلاحية إدارية خارج مسار الاعتماد المعتاد.



المراقبة والكشف (الشكل)





جدول طبقات الدفاع بالعمق والضابط الممثل

الطبقة	التهديد المستهدف	الضابط الوقائي	الضابط الكاشف	مؤشر المراجعة
الفيزيائية	دخول غير مصرح به	تحكم إلكتروني في الدخول	مراجعة سجل الدخول	مطابقة سجل الزوار أسبوعياً
الشبكة	وصول غير مصرح به	جدار حماية وتقسيم مناطق	نظام كشف ومنع التسلل	مراجعة القواعد شهرياً
المضيف	خدمة غير محدثة	تحديثات وتعطيل خدمات	مراقبة سلامة الملفات	تقرير الثغرات المفتوحة
التطبيق	حقن استعلامات	تحقق المدخلات والاستعلامات المعلمة	سجل أخطاء التطبيق	مراجعة نتائج الإصلاح
البيانات وإدارة المفاتيح	تسريب ملف أو تعرض مفتاح	تشفير وخدمة إدارة مفاتيح	سجل استخدام المفاتيح	مراجعة تدوير المفاتيح
الهوية والوصول	كلمة مرور مسروقة	مصادقة متعددة العوامل و RBAC	مراجعة الرفض وتغييرات الأدوار	مراجعة الصلاحيات ربع سنوياً



جدول طبقات الدفاع بالعمق والضابط الممثل (تابع)



توزع المصفوفة الضوابط بين طبقات مختلفة، فلا يعتمد التصميم على أداة واحدة.

المستند: نموذج تعيين ضوابط الدفاع بالعمق

شركة الحلول التقنية والخدمات الرقمية

تطوير وإدارة المنصات الرقمية والخدمات السحابية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

نموذج تعيين ضوابط الدفاع بالعمق

منصة الموارد البشرية والخدمات السحابية، مراجعة تصميمية بتاريخ 17-04-2026

الطبقة	التحديد المستهدف	الضابط الوقائي الأساسي	الضابط الكاشف	مؤشر التحقق والمراجعة
الفيزيائية	دخول غير مصرح به إلى غرفة معدات الشبكة	تحكم إلكتروني في الدخول وتسجيل الزوار	مراجعة تنبيهات الكاميرات وسجل الدخول	مطابقة سجل الزوار مع سجلات الدخول أسبوعياً
الشبكة	مسح المنافذ أو محاولة الوصول غير المصرح به	جدار حماية وتقسيم الشبكة إلى مناطق مستقلة	نظام كشف ومنع التنسلل	مراجعة التنبيهات الحرجة وقواعد الجدار الناري شهرياً
المضيف	استغلال خدمة غير محدثة على خادم التطبيق	إدارة تحديثات وتعطيل الخدمات غير الضرورية	مراقبة سلامة الملفات وتنبيه البرمجيات الضارة	تقرير التحديثات الناجحة ونسبة الثغرات المفتوحة
التطبيق	حقن أوامر في حقول منصة الموارد البشرية	التحقق من المدخلات والاستعلامات المعلّمة وإدارة الجلسات	سجل أخطاء التطبيق وتنبيهات جدار حماية تطبيقات الويب	اختبار اختراق دوري ومراجعة نتائج الإصلاح
البيانات وإدارة المفاتيح	تسريب ملف رواتب أو تعرض مفتاح توقيع	تشفير البيانات وخدمة إدارة مفاتيح وفصل الأسرار عن الشيفرة	سجل استخدام المفاتيح وفحص الأسرار في المستودع	التحقق من تدوير المفاتيح ومراجعة تنبيهات الأسرار
الهوية والوصول	استعمال كلمة مرور مسروقة أو تجاوز صلاحية الدور	مصادقة متعددة العوامل وRBAC وفصل المهام	مراجعة محاولات الدخول المرفوضة وتغييرات الأدوار	مراجعة ربع سنوية للصلاحيات والحسابات غير النشطة
الوعي والمراقبة	مشاركة بيانات دخول أو تجاهل تنبيه أمني	توعية أمنية وإجراء واضح للإبلاغ عن الحوادث	منصة تجميع السجلات والتنبيهات المركزية	قياس إتمام التوعية وزمن الاستجابة للحوادث

تعمل الضوابط بوصفها طبقات متكاملة، في حادثة تعرض المفتاح، تخفف طبقة البيانات وإدارة المفاتيح الأثر، بينما تكشف طبقة المراقبة الفحص والتنبيه وتحد طبقة الهوية والوصول من نطاق المستودع المتأثر.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- أقرأ المصفوفة من الطبقة إلى التهديد ثم الضابط الوقائي والضابط الكاشف.
- تعالج طبقة البيانات وإدارة المفاتيح تسريب ملف الرواتب أو تعرض مفتاح التوقيع بالتشفير وخدمة إدارة المفاتيح وفصل الأسرار عن الشيفرة.
- لا يكفي الجدار الناري لمعالجة هذا الخطر، لأن الحماية تتطلب أيضاً مراقبة استخدام المفتاح وفحص الأسرار.



مثال محلول، تعيين ضوابط دفاع بالعمق

◀ **المعطيات:** تستهدف المنصة دخولاً غير مصرح به، واستغلال خدمة غير محدثة، وحقق أوامر، وتسريب ملف رواتب، واستعمال كلمة مرور مسروقة.

◀ **الخطوات:**

1. تعيين تحكم الدخول وسجل الزوار للطبقة الفيزيائية.

2. تعيين جدار الحماية وتقسيم المناطق للشبكة.

3. تعيين التحديثات وتعطيل الخدمات غير الضرورية للمضيف.

4. تعيين تحقق المدخلات وإدارة الجلسات للتطبيق.

5. تعيين التشفير وخدمة إدارة المفاتيح للبيانات، ثم المصادقة متعددة العوامل و RBAC للهوية.

◀ **النتائج:** تتوزع الضوابط بين طبقات مختلفة، فيحد إخفاق ضابط واحد من الأثر ولا يزيل الحماية كاملة.





خصص 10 دقائق لاختيار طبقتين لمعالجة تعرض محتمل لمفتاح توقيع في بيئة اختبار.

عين ضابطاً وقائياً وضابطاً كاشفاً ومؤشر مراجعة لكل طبقة، ثم اكتب سبباً يبين لماذا لا يكفي جدار الحماية لمعالجة تعرض مادة تشفير في ملف إعدادات.



نشاط تطبيقي، قرار الوصول المناسب



- ◀ تعمل المنشأة على منح صلاحية إنشاء أمر صرف للحساب fin-ops-01، وصلاحية اعتماد الأمر للحساب fin-approve-01. اقترح نموذج التحكم في الوصول الأنسب، وحدد قيوداً يمنع جمع الصلاحيتين في حساب واحد، ثم اشرح في سطرين كيف يسجل النظام محاولة مخالفة للقيد.
- ◀ اكتب إجابتك في جدول يتضمن الدور والعملية والقرار والمبرر.



- ◀ النموذج الأنسب هو التحكم القائم على الدور RBAC لأن صلاحيات الإنشاء والاعتماد ترتبط بأدوار وظيفية واضحة.
- ◀ يطبق النظام قيد فصل المهام لمنع جمع إنشاء أمر الصرف واعتماده في حساب واحد.
- ◀ عند محاولة الحساب fin-ops-01 اعتماد الأمر PAY-260414-117، يصدر قرار رفض ويسجل الحدث بالمرجع AUTHZ-260414-392 للمراجعة والمحاسبة.



- ◀ لدينا ثلاث حالات: نسخة ملف رواتب محفوظة في التخزين السحابي، وملف رواتب يراد كشف تعديله قبل الاستيراد، وإيصال سداد يحتاج جهة خارجية إلى التحقق من مصدره.
- ◀ حدد لكل حالة الهدف الأمني والآلية المناسبة، ثم بين كيف تحمي المنشأة المفتاح أو القيمة المستخدمة.
- ◀ استند إلى بيانات جدول القرارات ولا تضيف آلية غير واردة فيه.



- ◀ تستخدم نسخة ملف الرواتب تشفيراً متماثلاً لتحقيق السرية، ويحفظ مفتاح التشفير في خدمة إدارة مفاتيح مع تدوير دوري.
- ◀ يستخدم فحص التعديل تجزئة SHA-256 مع بصمة محفوظة في سجل الاستيراد لتحقيق تكامل البيانات.
- ◀ يستخدم الإيصال توقيعاً رقمياً لبصمته، ويحفظ المفتاح الخاص داخل خدمة إدارة مفاتيح بينما يتاح المفتاح العام للتحقق الخارجي.



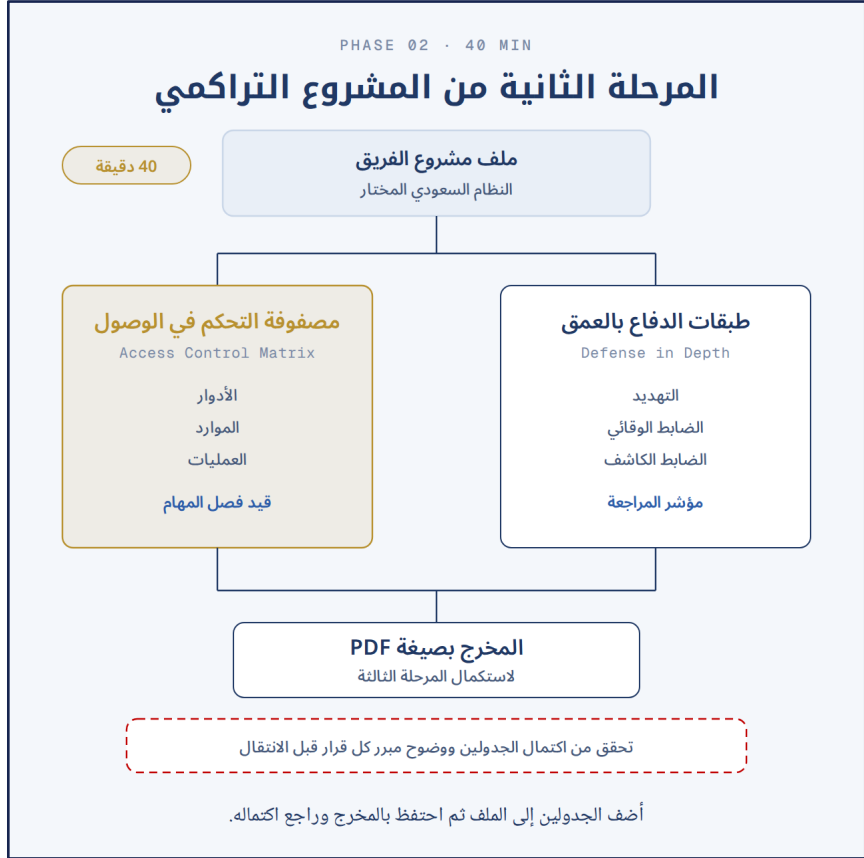
- ◀ تسجل المنصة تعرضاً محتملاً لمفتاح توقيع في ملف إعدادات بيئة اختبار.
- ◀ حل الطبقات التي تسهم في خفض أثر الحادثة.
- ◀ حدد ضابطاً وقائياً وضابطاً كاشفاً وإجراء مراجعة واحداً من المصفوفة.
- ◀ ثم بين لماذا لا تعد معالجة المفتاح المتأثر مسؤولية طبقة الشبكة وحدها.
- ◀ اكتب قرارك في خمسة أسطر مترابطة.



- ◀ تعالج طبقة البيانات وإدارة المفاتيح الحادثة بتشفير البيانات وخدمة إدارة مفاتيح وفصل الأسرار عن الشيفرة.
- ◀ يكشف سجل استخدام المفاتيح وفحص الأسرار في المستودع مؤشرات التعرض.
- ◀ تتحقق المنشأة من تدوير المفاتيح وتراجع تنبيهات الأسرار.
- ◀ تسهم طبقة الهوية والوصول في تقييد الوصول الإداري، وتسهم المراقبة في مراجعة السجلات، لذلك لا تكفي طبقة الشبكة وحدها.



المرحلة الثانية من المشروع التراكمي



- الزمن المقدّر: 40 دقيقة.
- أضف إلى ملف مشروع فريقك للنظام السعودي المختار مصفوفة تحكم في الوصول تشمل الأدوار والموارد والعمليات وقيد فصل المهام، ثم جدول طبقات الدفاع بالعمق يربط التهديد بالضابط الوقائي والضابط الكاشف ومؤشر المراجعة.
- احتفظ بالمخرج بصيغة PDF لاستكمال المرحلة الثالثة.
- تحقق من اكتمال الجدولين ووضوح مبرر كل قرار قبل الانتقال.



✓ **قارنت** نماذج DAC و MAC و RBAC و ABAC وفق أساس القرار وملاءمة السياق المؤسسي.

✓ **ميزت** بين المصادقة التي تثبت الهوية، والتفويض الذي يحدد الصلاحية، والمحاسبة التي تربط الحدث بسياقه.

✓ **طبقت** الدفاع بالعمق بتعيين ضوابط وقائية وكاشفة عبر طبقات متعددة.

✓ **شرحت** دور التشفير والتجزئة والتوقيع الرقمي وإدارة المفاتيح في حماية السرية وتكامل البيانات.

✓ **صممت** مصفوفة وصول مبسطة تفصل إنشاء أمر الصرف عن اعتماده وتدعم المراجعة المستقلة.



1. Anderson, Ross. (2020). Security Engineering: A Guide to Building Dependable Distributed Systems (3rd ed.). Wiley.
2. Stallings, William. (2017). Cryptography and Network Security: Principles and Practice (7th ed.). Pearson.
3. Johnsson, D. B., Deogun, D., & Sawano, D. (2019). Secure by Design. Manning.
4. National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations. NIST SP 800-53 Rev. 5, Update 1.
5. National Institute of Standards and Technology. Digital Identity Guidelines. NIST SP 800-63-4.
6. National Institute of Standards and Technology. Recommendation for Key Management: Part 1, General. NIST SP 800-57 Part 1 Rev. 5.

7. الهيئة الوطنية للأمن السيبراني. الضوابط الأساسية للأمن السيبراني.



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شكراً لكم

معهد البحوث والخدمات الاستشارية – جامعة جازان